

Key Management Lifecycle Best Practices



The permanent and official location for Cloud Security Alliance Cloud Key Management research is <https://cloudsecurityalliance.org/research/working-groups/cloud-key-management/>.

© 2023 Cloud Security Alliance – All Rights Reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance at <https://cloudsecurityalliance.org> subject to the following: (a) the draft may be used solely for your personal, informational, non-commercial use; (b) the draft may not be modified or altered in any way; (c) the draft may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the draft as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance.

Acknowledgments

Lead Authors

Sunil Arora
Santosh Bompally
Marina Bregkou
Parthasarathy Chakraborty

Contributing Authors

Iain Beveridge
Christian Bollich
Rajat Dubey
Parth Jamodkar
Vasan Kidambi
Vrettos Moulos
Vani Murthy
Sam Pfanstiel
Carlos Rombaldo Jr.
Michael Roza
Aakash Shah
Alex Sharpe

Reviewers

Marcin Jekot
Alex Rebo
Jim Scardelis

CSA Staff

Marina Bregkou
Claire Lehnert
Stephen Lumpe

Table of Contents

1. Introduction	6
1.1 Purpose	6
1.2 Scope	6
1.3 Target Audience	6
2. Key Management Refresher	7
2.2 Cryptographic Algorithms and Keys	9
2.2.1 Crypto-Agility	10
2.3 KMS Overview	10
2.4 HSM Overview	12
2.5 Secrets Management Refresher	14
2.5.1 Secrets Management.....	14
2.6 Capabilities & Matrix Overview	15
3. Deep Dive into Each Item in the Lifecycle and Features	17
3.1 Lifecycle Overview	18
3.2 Lifecycle Phases and Features	18
3.2.1 Key Generation	18
3.2.2 Key Distribution	19
3.2.3 Key Storage	21
3.2.4 Key Usage State/Phase	21
3.2.5 Key Backup/Recovery	22
3.2.6 Key Revocation State	23
3.2.7 Key Rotation	25
3.2.8 Key Destruction	26
4. Planning for Key Management Lifecycle Solution	28
4.1 Technical Considerations	31
4.2 Operational Considerations	33
4.3 Financial Considerations	34
4.3.1 Financial Considerations for On-Premises and Multi-Cloud	34
4.4 Recommended Best Practices	36
4.4.1 Recommended Best Practices for On-Premises and Multi-Cloud.....	36
4.4.2 Best Practices for Implementing a Key Management Lifecycle Solution.....	37
5. Deployment of Key Management Lifecycle Solution	38
5.1 Deployment Approaches	38

5.1.1 Hardware-Based HSM Deployment Approach	38
Hardware-Based HSM Overview	38
5.1.1.1 Deployment Approach for HSM.....	38
Deployment in the Cloud	39
Hybrid Environment	39
HSM-as-a-Service Mode	40
5.1.2 Software-Based HSM Overview Deployment Approach	40
Software-Based HSM Overview	40
Deployment Approach for Software-Based HSM with Cloud Service Provider Keys	41
Deployment Approach for Software-Based HSM with Customer Managed Keys	41
5.2 Deployment Considerations	41
5.3 Operations and Maintenance	45
5.4 Auditing Requirements	45
6. Industry Specific Differences	48
7. On Premises-Considerations.....	50
8. Conclusion	52
9. References	53
Appendix A: Acronyms	55

1. Introduction

1.1 Purpose

Cryptographic keys encrypt and decrypt sensitive data, authenticate users and devices, and provide secure communication channels. These keys are essential for securing digital assets, and managing the keys can be challenging for organizations running applications in the cloud or data centers. Failure to securely manage cryptographic keys may lead to security breaches, data loss, and regulatory compliance issues.

There are various regulatory requirements related to key management, such as PCI DSS (Payments Card Industry Data Security Standard), GDPR (General Data Protection Regulation), and HIPAA (Health Insurance Portability & Accountability Act), that organizations may need to comply with. In addition, there are many guidelines for cryptographic key management like NIST (National Institute of Standards & Technology) and US Government standards on cryptographic module security and key management such as FIPS 140-2 and FIPS 140-3. These requirements ensure the confidentiality, integrity, and availability of sensitive data and systems that use cryptographic keys. However, how to achieve compliance with regulatory requirements must be clarified in the best possible way for enterprise customers and service providers.

This document serves as a guideline for enterprise technologists and service providers to manage cryptographic keys effectively and securely throughout the lifecycle to protect the digital assets and maintain regulatory compliance.

1.2 Scope

The scope of the Key Management Lifecycle Best Practices document is to provide guidance, procedures, and important considerations for the secure management of cryptographic keys at every stage of the key lifecycle, regardless of the type of encryption algorithms or keys.

The document commences with a refresher on key management concepts, an introduction, and an overview of the key management processes, and then outlines best practices for each phase of the key management lifecycle. It also covers planning and deployment considerations for technical, operational, regulatory, and financial aspects.

1.3 Target Audience

The primary audience for this document is enterprise technologists and cloud service providers. People in the following roles will find relevant information to do their jobs:

- Enterprise and security architects,
- Information security specialists,
- Compliance and regulatory experts,
- Legal team,
- Developers,
- System and network administrators, and
- Operations specialists.

This document will also help security leaders and managers understand the overview of the key management phases and guide them to make technology decisions related to key management. It targets consumers from all industries, government, and public sectors involved in cryptographic activities to secure the confidentiality, availability, and integrity of digital assets.

2. Key Management Refresher

Key management refers to generating, distributing, storing, maintaining, backing up, and recovering (in case of an event), revoking, and destroying cryptographic keys to secure an organization's digital assets. Key management concepts include key management systems, hardware security modules, vaults¹, and secret managers. Effective key management is crucial to maintain the security and functionality of cryptographic techniques. If key management is weak or compromised, unauthorized access, data breaches, and the loss of confidential or sensitive information can result. For this reason, both individuals and organizations need to implement strong key management practices to safeguard their data and communications.

However, it sometimes becomes challenging to understand the key management concepts and how different use cases, best practices, and guidelines apply to an organization. This section provides a refresher for someone new to the field of key management to have a common understanding before diving deeper into the technical, operational, and financial best practices of key management systems across different industry needs.

Cryptography is the practice and study of techniques for [secure communication](#) in the presence of [adversarial](#) behavior. (Rivest, Ronald L. (1990). "Cryptography." In J. Van Leeuwen (ed.). Handbook of Theoretical Computer Science. Vol. 1. Elsevier.)

Cryptography can be used to fulfill all three dimensions of the CIA Triad (i.e., confidentiality², integrity³, and availability⁴). Cryptography also plays a role in attacking each leg of the triangle. The most obvious is the use of cryptography in Ransomware attacks, where valid users are prohibited from accessing their data because it has been encrypted. Valid users must pay the perpetrator(s) a ransom to get the key to decrypt their data.

1 A vault is a secure repository for storing and managing cryptographic keys and other sensitive data. It provides a centralized location to control access to these critical assets and ensure their integrity and availability.

2 <https://csrc.nist.gov/glossary/term/confidentiality>

3 <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>

4 <https://csrc.nist.gov/glossary/term/availability>

Cryptography can also be used to provide services like Notarization⁵ and Non-Repudiation⁶. The rise of cryptosystems created new products like Cryptocurrencies⁷, Non-Fungible Tokens (NFTs), and to perform Digital Rights Management (DRM). Cryptography is also at the core of Smart Contracts and anything Blockchain.

Section 2.1 provides an overview of encryption. For the sake of simplicity we will not provide a detailed description of other uses.

2.1 Encryption Overview

As described in the “[Key Management in Cloud Services](#)” document previously published by this working group [3], the Key management process plays an important role in securing any enterprise whether in the cloud or on premises or in a hybrid environment.

As per NIST SP 800-175 Br1, encryption⁸ is “The process of changing plaintext into ciphertext using a cryptographic algorithm and key.” Encryption transforms plain text, like a message, into an indistinguishable string of bits called ciphertext that can be read only by a party who knows the algorithms, and the settings, and possesses the correct key. This process involves applying a mathematical computation or calculations consisting of rules and instructions known as an encryption algorithm. The recipient must possess a unique parameter known as a cryptographic or encryption key to decipher the message. NIST defines a cryptographic key as a parameter that operates with the cryptographic algorithm to perform its functionality and is crucial in ensuring data security. The key also enables authorized entities to replicate or undo the cryptographic operation (e.g., decryption). On the other hand, entities without the key or appropriate authorization cannot execute these operations, thus ensuring confidentiality and potentially the integrity of the information. [1]

Regularly rotating encryption keys is crucial to mitigate the risk of key compromise and exhaustion*. Key rotation ensures that even if a key is compromised, the impact is limited to a specific timeframe, reducing the potential damage. The period in which a key is used is called the “cryptoperiod”. A cryptoperiod is the time span during which a specific cryptographic key is authorized for use. This timespan may depend on several factors, including but not limited to the number of messages or volume of the data encrypted with one key, the data’s life span, the algorithms’ strength, and key length. Common cryptoperiods for asymmetric keys from 1 to 2 years. Symmetric keys, commonly used for data encryption in security-sensitive environments, have a short cryptoperiod ranging from 1 to 7 days for shorter duration encryption requirements (such as communication between network nodes) and an extended cryptoperiod from 1 to 2 years for long-term use cases (such volume encryption). In scenarios where encrypted data is stored longer (encrypted backup tapes or drives), it becomes imperative to reapply protection mechanisms using a new cryptographic key. [2].

5 <https://www.nationalnotary.org/notary-bulletin/blog/2020/03/notary-technology-digital-certificates>

6 https://csrc.nist.gov/glossary/term/non_repudiation

7 <https://www.irs.gov/businesses/small-businesses-self-employed/digital-assets>
<https://www.irs.gov/businesses/small-businesses-self-employed/digital-assets>

8 Please note that many KMS can manage symmetric keys for encryption use cases and asymmetric keys which are usually not used for encryption but signing/authentication for use cases like code signing.

Keys may also be rotated sooner because of a compromise, a suspected compromise, system changes, and role changes (e.g. employee changing departments, changing jobs or increased duties, etc.). Factors to consider for key rotation include the strength of the underlying encryption algorithm, key length, the likelihood of compromise, and the availability of mechanisms for revoking keys.

*Key exhaustion is a cryptanalysis technique that involves using a cryptographic key so extensively that it becomes vulnerable to attack. Excessive usage of a cryptographic key makes it susceptible to attack, as it can create patterns in the ciphertext that attackers can exploit to decrypt messages [13].

**Please note here that, regularly rotating encryption keys is a best practice for security, but it does also introduce operational risks that need to be carefully managed. The operational risks associated with key rotation can include the potential for system unavailability or even data loss if not handled properly. So, while key rotation is crucial for mitigating the risk of key compromise and exhaustion, it should be approached with careful planning and consideration of operational risks. There must be a careful balance between security and operational continuity to ensure that key rotation procedures are effective without causing undue disruption or data loss.*

2.2 Cryptographic Algorithms and Keys

There are primarily two types of encryption algorithms: Symmetric Key and Asymmetric Key.

Symmetric key algorithms use a single key for both encrypting and decrypting data. The same key is applied to provide cryptographic protection and remove the protection. To illustrate, the key employed to encrypt the original data (plaintext) is identical to the one used for decrypting the encrypted data (ciphertext). As encryption and decryption use a single key, it is crucial to keep the key confidential to protect the data. Examples of symmetric key algorithms are Advanced Encryption Standard (AES) and Triple Data Encryption Algorithm (TDES⁹).

Asymmetric key algorithms, also called public-key algorithms, use a pair of keys — a private key and a public key — that are mathematically associated. The public key is shared with others without affecting the security of the process. However, the private key must be kept confidential to secure cryptographic protection. Although the keys are related, it is not feasible to determine the private key based on the public key's knowledge¹⁰.

⁹ In bibliography the abbreviation of the triple data encryption algorithm is met as 3DES also.

¹⁰ When someone wants to send a secure message to another party, they obtain the recipient's public key and use it to encrypt the message. Once encrypted, only the corresponding private key, held exclusively by the recipient, can decrypt and reveal the original message. This asymmetry in key usage ensures confidentiality and authenticity in communication. Additionally, asymmetric cryptography is often used for digital signatures, where the sender uses their private key to sign a document or message, and others can verify the signature using the sender's public key, confirming both the sender's identity and the document's integrity. This dual-key approach underpins secure communication, online transactions, and the overall security of the digital world.

2.2.1 Crypto-Agility

Crypto or cryptographic agility is an organization's ability to adopt different cryptographic standards quickly without significant impact on the organization (e.g., time, cost, disruption). It has become a mainstream concern because of a combination of the cloud, advances in computing power, and quantum computing¹¹. With new crypto analytical techniques becoming viable, including quantum computing, along with the changes in the economics of attacking cryptographic systems, more than simply increasing the length of a key is required.

Organizations must embrace crypto agility to proactively adapt to the evolving cryptographic landscape and ensure the long-term security of their data¹². To achieve crypto-agility, a key management system (KMS) that can adapt to various key formats and lengths over time is crucial. Implementing a well-documented corporate policy and a strict communication plan is an effective way to ensure crypto-agility. Larger organizations will have a standalone key management policy (KMP) while smaller organizations may have it as part of another corporate policy [7].

An important part of crypto-agility is the replacement of cryptographic algorithms with more robust and more resistant algorithms without significant impact to the organization. Because a full discussion is outside the scope of this document we discuss here only the key management aspects. Key management practitioners need to be aware that bad actors can acquire encrypted data now anticipating breakthroughs in cryptology and advances in technology like quantum computing that would render the data readable later. This is sometimes referred to crypto harvesting, harvest now, decrypt later (HNDL), store now, decrypt later (SNDL) or retrospective decryption.

2.3 KMS Overview

A key management system (KMS) manages cryptographic keys for the entire life cycle of a given domain, usually an enterprise or a business unit. The National Institute of Standards and Technology (NIST) [4] defines a KMS as "A system for the management of cryptographic keys and their metadata (e.g., generation, distribution, storage, backup, archive, recovery, use, revocation, and destruction). An automated key management system may be used to oversee, automate, and secure the key management process".

11 While the practical application of quantum computers breaking modern cryptography is not certain it is a threat that organizations should be aware of and prepare for now, in order to reduce the impact later. The development and adoption of quantum-resistant cryptography are ongoing efforts to mitigate this threat. Organizations should assess their cryptographic needs, stay informed about quantum computing advancements, and be prepared to transition to quantum-resistant algorithms when necessary. However, implementing a quantum-resistance policy may take several years and it is crucial to start the process early and plan for a smooth transition to quantum-resistant cryptographic methods to protect sensitive data in the future quantum computing era.

12 The economics of cryptography involve a continuous assessment of the costs and benefits associated with securing information and the potential gains for attackers seeking to compromise it. Organizations need to stay informed about emerging threats, technological advancements, and the evolving field of cryptanalysis to make informed decisions about their security measures. They should examine: computational resources, key length considerations, cost of attacks, cryptanalysis advances, incentives and motivations.

The International Organization for Standardization (ISO) has a similar but long-standing definition: “Key management includes functions such as the generation, storage, distribution, deletion, and archiving of keying material in accordance with a security policy”. [5]

Key management in the cloud is more complex and can vary widely depending on specific implementation and delivery models. Key management is part of the overall security framework within the cloud infrastructure. The KMS is typically used by cloud consumers (e.g., enterprises or individuals) to manage their cryptographic keys in the cloud and by cloud providers to manage keys used for their services (e.g., storage, database, or messaging services).

2.3.1 Cloud-Native KMS

Cloud service providers offer native key management systems that support several key management patterns, and their capabilities here continue to evolve. Native key management services are tightly integrated with the fabric of the CSP and their services. Cloud-native KMS are usually (although, not always) built on a shared array of hardware security modules (HSM) and exposed as an application programming interface (API) to be consumed by the cloud customer [6]. In addition, users can buy other KMS appliances¹³ through the marketplace or use external KMS solutions that integrate with the CSP.

Cloud-Native KMS may support various types of key responsibility patterns:

1. **Cloud Service Provider Managed Keys:** Key lifecycle management is the responsibility of the CSP, and the cloud customer never interacts with the key. An example is a cloud-native database encrypting data at rest natively using keys managed by the CSP.
2. **Customer Managed Keys¹⁴:** These architectures allow the cloud customer to generate keys (or key material) in their own KMS and import them into a cloud HSM. Variations in these architectures include architectures where it is possible to revoke the key by storing it in KMS appliances under the customer’s control (also called control your own key).
3. **Customer Held Keys¹⁵:** Hold your own key architectures enable customers to maintain control of the keys within their own (customer-managed) KMS solutions. The customer-managed KMS solution controls encryption key operations and requests. This means that the customer retains control over the cryptographic keys used to protect their data, even when that data is stored in a cloud service provider’s environment.

The table below outlines the shared responsibility model for these key patterns. The table notes primarily responsibility, but the CSP or customer may play an additional role in the function. It is important to note that, in the end, the customer is still responsible for the security of their applications and the overall key management lifecycle.

¹³ From different providers like [Akeyless](#), [AWS](#), [Cosmian](#), [Oracle](#).

¹⁴ Widely referred to as BYOK: Bring Your Own Key.

¹⁵ Widely referred to as HYOK: Hold Your Own Key.

	CSP Managed Keys	Customer Managed Keys	Customer Held Keys
Key Generation	CSP	Customer	Customer
Key Distribution	CSP	Customer	Customer
Key Rotation	CSP	Customer	Customer
Key Use	CSP	CSP/ Customer	CSP/ Customer
Key Storage	CSP	CSP	Customer
Key Revocation	CSP	Customer	Customer
Key Backup	CSP	Customer	Customer
Key Auditing	CSP	Customer	Customer
Availability	CSP	Customer	Customer
Performance	CSP	CSP	Customer

Table 1: Shared Responsibility Model

2.4 HSM Overview

A hardware security module (HSM) is a hardware device designed to manage and protect cryptographic keys throughout their lifecycle. HSM is used when security, high assurance, and confidentiality are critical and require customers to completely control the encryption keys. These scenarios may include banking, finance, government, enterprise, healthcare, and e-commerce. HSMs are typically hardened, tamper-evident, or tamper-responsive design, which means that they are resistant to attack from bad actors, and attempts to access the device will destroy the keys and the data stored within the HSM. Most HSMs are certified to the highest security standards, including FIPS 140-2/ 140-3, PCI PTS HSM and Common Criteria (CC)^{16,17}.

HSMs provide various cryptographic services, including encryption, decryption, digital signature generation, and verification. They can perform key management functions, such as generation, distribution, renewal, and revocation. HSMs not only provide a secure environment that protects keys throughout their lifecycle, but they also provide strong controls (enforced within the secure boundary of the HSM) in order to determine which roles are granted access to the keys and define the actions those roles can perform with the keys.

They are typically available in various form factors, including USB-connected, embedded PCIe cards, and network-attached HSMs. The choice of HSM depends on the specific use case and the level of security required. Overall, HSMs are an essential component in building secure and reliable systems that require the highest levels of protection.

¹⁶ Please note that in order for an HSM to be covered by one of these certifications, it also has to be configured in accordance with the security policy associated with that certification.

¹⁷ CC compliance requires specifying the exact profile or target to provide clarity about the security features and standards to which the product adheres.

The diagram below illustrates the various KMS patterns, including cloud KMS, cloud HSM, on-premises HSM and a hybrid solution.

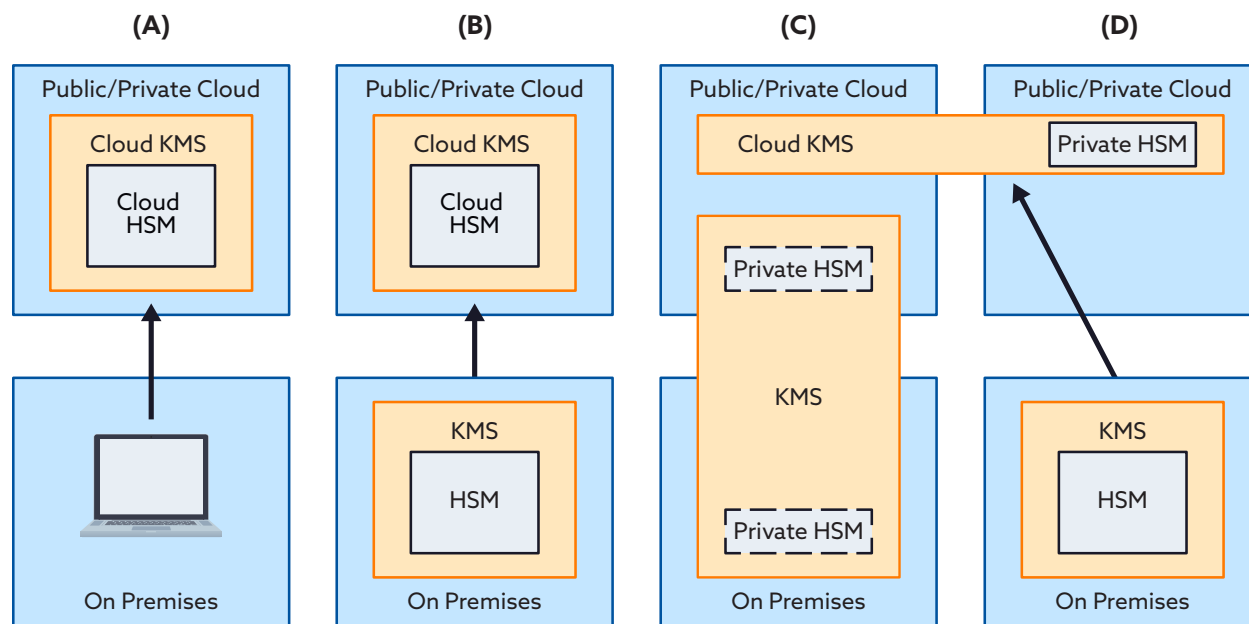


Figure 1. Cloud and on-premises KMS patterns (Ref: CSA document - key management in Cloud Services).

Figure 1 illustrated the following key management patterns:

1. (A) is a cloud service that leverages a KMS (including HSM) within that same cloud;
2. (B) expands pattern (A) to allow for the import of key material from an external KMS;
3. (C) is a cloud KMS with a dedicated (private) HSM that is under control of the owning organization, but is physically hosted within the cloud provider's data center(s);
4. (D) illustrates an on-premises KMS that is used for multi-cloud KMS integration/management that can be hosted either on premise or in the cloud and is linked to an on-premise

2.5 Secrets Management Refresher

2.5.1 Secrets Management

While secrets management is not a part of key management systems, the two concepts have some relation and can be confusing for someone new to the field. This refresher section addresses this overlap. Key management systems are used to secure the keys for cryptographic functions, while secret management handles secrets such as API keys, system passwords, and other credentials. Secrets management is the practice of securely storing, managing, and accessing sensitive information including passwords, API keys, and other credentials. Secrets are crucial for various applications and systems authentication, authorization, and data protection. Effective secrets management ensures that these sensitive pieces of information are kept confidential, properly controlled, and audited throughout their lifecycle.

Effective secrets management offers centralized management, granular access controls, automated key rotation, and auditability, making it a preferred option over in-bucket encryption for ensuring the confidentiality and integrity of secrets in cloud environments. Implementation of secrets management involves:

Secure Storage: Secrets are securely stored within a secrets management system using strong encryption and access controls. Secrets management systems are designed to prevent unauthorized direct access to sensitive information, including encryption keys, thereby adding an additional layer of security to sensitive data.

Access Controls: To ensure better security, it is recommended that role-based authentication be used instead of granting direct access to individual users. This method permits only authorized users to perform administrative actions. Applications can leverage roles to use stored keys while enforcing access controls based on the roles, permissions, and policies established for each user.

Auditing and Logging: The KMS maintains detailed audit logs of all key-related activities (the cryptographic keys managed by the KMS), including key generation, retrieval, rotation, and deletion. This helps track who accessed the keys and when.

Secret Rotation: Secrets, including encryption keys, should be rotated periodically to reduce the risk of unauthorized access. The KMS facilitates secure key rotation without exposing the keys themselves.

Secret Versioning: Key management systems often support key versioning, which allows organizations to manage multiple versions of a key. This is useful for phased key rotation and backward compatibility. Some best practices from the key management perspective include: secure key storage, separation of duties, key rotation, multi-factor authentication, secure backup and recovery, versioning, etc.

2.6 Capabilities & Matrix Overview

This section compares the features and capabilities of cloud and on-premises key management systems. The detailed matrix that follows presents a comprehensive view of the differences between cloud key management systems (KMS), cloud hardware security modules (HSM), and on-premises HSM.¹⁸

Capability	Cloud KMS	Cloud HSM	On-premises HSM
Infrastructure	Shared environment	Dedicated hardware	Dedicated hardware
Scalability and Flexibility	Highly scalable and flexible.	Highly scalable and flexible.	Limited scalability, requires upfront planning.
Maintenance and Updates	Managed by cloud service provider.	Managed by cloud service provider. ¹⁹	Organization's responsibility.
Accessibility and Integration	Remote access.	Remote access.	Local & Remote access.
Disaster Recovery and High Availability	Built-in DR and HA (multi availability zones, multi-region keys) features provided by the cloud service provider.	Built-in DR and HA(multi availability zones, multi-region keys) features provided by the cloud service provider.	Organization's responsibility.
Key Lifecycle Management	Full key lifecycle management.	Full key lifecycle management.	Full key lifecycle management.
Key Generation and Storage	Secure key generation and storage.	Secure key generation and storage.	Secure key generation and storage.
Key Distribution and Rotation	Secure key distribution and rotation.	Secure key distribution and rotation.	Secure key distribution and rotation.
Key Revocation and Deletion	Secure key revocation and deletion.	Secure key revocation and deletion.	Secure key revocation and deletion.

¹⁸ Section 4.3.1 describes the comparisons for Cloud vs. On-premises KMS.

¹⁹ It may depend on the contract. For example, an HSM-as-a-service provider may have such an offering. However, for cloud HSM, CSPs are primarily responsible for maintenance and updates. [14]

Access Controls and Audit Trails	Granular access controls and robust audit trails (varies based on CSPs).	Granular access controls and robust audit trails (varies based on CSPs).	Granular access controls and robust audit trails (varies based on HSM provider).
Encryption Algorithm Support	Wide range of encryption algorithms supported.	Wide range of encryption algorithms supported.	Wide range of encryption algorithms supported.
Cryptographic Module Validation Program (FIPS 140-2)	Certification available.	Certification available.	Certification available.
Integration with Cloud Services and APIs	Seamless integration with cloud services and APIs.	Seamless integration with cloud services and APIs.	Integration capabilities vary ²⁰ .
Disaster Recovery and High Availability	Built-in features provided by the cloud service provider.	Built-in features provided by the cloud service provider.	Organization's responsibility.

²⁰ CSPs may have additional functionalities/APIs that make cloud services integration easy. For example, Google Cloud HSM: Cloud HSM and Cloud KMS share a common management and data plane API. The internal details of communicating with an HSM are abstracted from the caller.

Consequently, no code changes are required to update an existing application that uses software keys in Cloud KMS to support HSM-backed keys. Instead, the resource name of the key to use is updated.[15]

3. Deep Dive into Each Item in the Lifecycle and Features

The encryption key management lifecycle refers to the entire key lifecycle from creation to destruction. It refers to the stages and processes an encryption key goes through during its lifetime. At each key management phase, consistent enforcement of policies and controls must be in place to secure the keys. Therefore, implementing appropriate security policies, standards, guidance, and controls, and mechanisms is important to maintain the keys and key management systems' availability, integrity, and confidentiality.

The following are the key management lifecycle phases:

1. Key Generation
2. Key Distribution
3. Key Storage
4. Key Usage
5. Key Backup and Recovery
6. Key Revocation
7. Key Rotation (otherwise called key renewal or key update)
8. Key Destruction- Disposition

Key Roles and Responsibilities: Here are some of the typical roles and responsibilities in KMS lifecycle phases:

1. KMS Administrator:
 - Manages and configures the KMS system
 - Ensures proper access controls and permissions for key management
2. Key Generator
 - Generates cryptographic keys with sufficient entropy.
 - Ensures keys are generated using approved algorithms and lengths
3. Key Custodian
 - Safely stores and manages keys throughout their lifecycle
 - Handles key distribution, rotation, and destruction
4. Key User
 - Uses keys for cryptographic operation in authorized applications
 - Complies with key usage policies and security best practices
5. Auditor
 - Conducts regular audits to ensure compliance and identify vulnerabilities
 - Reviews key management practices for security and efficiency
6. Compliance Officer
 - Ensures that KMS aligns with relevant regulatory requirements and standards
 - Maintains compliance with data protection and privacy regulations

7. System Administrator
 - Manages and maintains the KMS infrastructure, including hardware and software components
 - Ensures the availability and reliability of the KMS system.

3.1 Lifecycle Overview

Key management refers to the management of cryptographic keys through the entire life-cycle from inception to destruction which for the purpose of discussion can be parsed into eight areas:

- Key Generation
- Key Distribution
- Key Storage
- Key Usage
- Key Backup and Recovery
- Key Revocation
- Key Rotation
- Key Destruction and Disposition

Successful key management is critical to the security of any enterprise and, in today's interconnected world, critical to supply chains. Key management is generally regarded as the most challenging part of any cryptographic system.

It is important to be mindful that while based on technology, a successful key management system relies heavily on people, processes, and organization along with the technology.

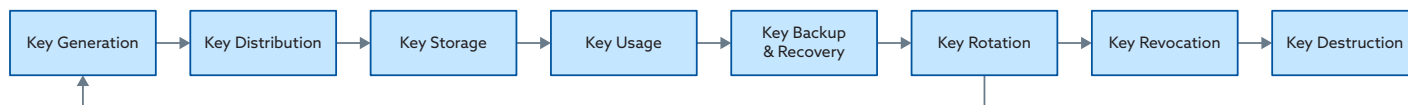


Diagram 2: Key Lifecycle

3.2 Lifecycle Phases and Features

3.2.1 Key Generation

Generating keys is the first step in the key management lifecycle. This process involves choosing the appropriate cryptographic algorithms, key length, and randomness to create secrets. There are primarily two mechanisms used for generating cryptographic keys — software-based and hardware-based. The software-based method involves using a software library like OpenSSL to generate the keys. The hardware-based method involves using a hardware security module (HSM) that utilizes firmware to generate the keys. It is recommended to use established cryptographic algorithms such

as RSA, AES, or Elliptic Curve Cryptography (ECC), and the key length should be chosen based on security and performance requirements. Random Number Generators (RNGs) are crucial in the key generation process as they ensure the randomness of the generated keys. It is advisable to use an approved RNG that complies with recognized standards such as NIST SP 800-90A, FIPS 140-2/140-3, or BSI AIS 20/31 to ensure the security of the generated keys. After the appropriate cryptographic algorithms, key length, and randomness, are selected, the keys can be generated. This can be achieved using FIPS-compliant software or hardware-based modules, such as HSMs.

3.2.2 Key Distribution

Cryptographic key distribution is the process of securely distributing the encryption keys between authorized parties, applications, and systems for specific purposes, such as for the data encryption and decryption function. This phase focuses on secure distribution of the keys to ensure the confidentiality and integrity of encryption keys. Below are some examples of commonly used approaches.

1. **Symmetric Key Distribution:** Symmetric encryption algorithms rely on a single shared key for both encryption and decryption. To securely distribute the key, the sender and receiver exchange it through secure means, such as in-person meetings or secure file transfers. Alternatively, they can use secure key exchange protocols like the Diffie-Hellman key exchange.
2. **Asymmetric Key Distribution:** Asymmetric encryption involves public and private keys, which both the sender and receiver hold. The sender uses the receiver's public key to encrypt the data, and then the receiver decrypts it using their private key. This can also happen in reverse order for signatures (public for validation by recipient, private for signature). Asymmetric keys can be securely distributed using Public Key Infrastructure (PKI), and key exchange protocols.
3. **Key Distribution Centers (KDC):** A Key Distribution Center is a secure and centralized system that distributes encryption keys to communicating parties. It acts as a trusted intermediary and generates session keys for symmetric encryption. The Kerberos protocol is a well-known example of a Key Distribution Center system which can be used also for key exchange.
4. **Pre-Shared Keys (PSK):** Pre-shared keys are symmetric keys shared beforehand by communicating parties. They are frequently used in scenarios where a restricted number of parties require secure communication, such as in Virtual Private Networks (VPNs) or wireless networks. It is essential to securely distribute PSKs²¹ through out-of-band methods

²¹ This exchange can happen through various methods, depending on the security requirements and the communication environment:

- **In-Person Exchange:** In a physically secure environment. This ensures a high level of security but may not be practical for remote or automated systems.
- **Secure Channel:** If a secure communication channel exists between the parties, the PSK can be exchanged over that channel. This could be an encrypted email, a secure messaging platform, or any other secure communication protocol.
- **Out-of-Band:** An out-of-band method involves using a separate communication channel to transmit the PSK. For example, a PSK could be sent via SMS or phone call to a trusted recipient.
- **Trusted Third Party:** This third party would ensure that the PSK is securely distributed to both parties without direct communication between them.

to prevent interception or compromise.

5. **Key Exchange Protocols:** With key exchange protocols, like the Diffie-Hellman key exchange, two parties can generate a shared secret key over an insecure communication channel without actually sending the key. These protocols (e.g., Diffie-Hellman (DH), Secure Remote Password (SRP), RSA Key Exchange (RSAKE), etc.) use mathematical calculations to generate the key without revealing it during the exchange.
6. **Envelope encryption** is a technique used in information security to provide additional protection for sensitive data and help to share the keys in an encrypted format. It involves encrypting data using multiple encryption keys²², using one key to encrypt the data itself (referred to as the data key), and another key is used to encrypt the data key (known as the key-encryption key or KEK). This approach helps enhance security by separating the management of the data keys and the KEK management. Organizations can achieve improved security through the use of envelope encryption.. In addition, it allows for different access controls and encryption mechanisms to be applied to the data key and the KEK, limiting the exposure of sensitive information [4].
7. **'M of N' Algorithm:** The "m of n" algorithm, such as Shamir's Secret Sharing (SSS) and Verifiable Secret Sharing (VSS), is a cryptographic technique that enables the secure distribution of a key among multiple parties. The key is not stored entirely by any single party, but rather is divided into n shares, with each party holding a different share. To reconstruct the original key, any m out of n shares must be combined. This technique is commonly used in industries such as banking and finance to share the key and ensure that multiparty consent is obtained, requiring collaboration to perform cryptographic operations.

It is essential to use secure channels, proper authentication mechanisms, and protection against key tampering or interception to ensure the security of encryption keys. Some measures would namely be:

- Mutual authentication,
- Secure channels
- Key wrapping: techniques to protect the keys during transmission. Key wrapping involves encrypting the key with another encryption key before transmission, adding an extra layer of protection against tampering.
- Symmetric encryption
- Key escrow: please see section 3.2.5 below.
- Limited access, etc.

22 Envelope Encryption, uses at least two encryption keys:

- A. Key Encryption Key (KEK): The master key used to encrypt and protect the Data Encryption Key (DEK). This KEK is typically a high-entropy and long-lived key stored in a secure key management system.
- B. Data Encryption Key (DEK): The encryption key used to encrypt the actual data. This DEK is unique for each piece of data being encrypted and is often generated dynamically for each encryption operation.

The process can be extended to include additional layers of encryption using different keys for added security.

3.2.3 Key Storage

The **key storage** phase ensures **secure storage and controlled access to cryptographic keys**. One of the common methods to achieve this is by storing cryptographic keys in a centralized and secure location, such as a hardware security module (HSM). Cryptographic keys may be stored in immediate, accessible, secure storage or removable media with controlled physical and logical access. Access controls should be established to prevent unauthorized access. In addition, encryption (such as key wrapping) may be applied to maintain the confidentiality of the keys. Organizations must consider compliance and regulatory requirements, such as [FIPS 140 levels](#) when considering storage-level encryption techniques.

3.2.4 Key Usage State/Phase

In the context of key management, “Key usage” is generally considered a state that refers to the current status of a cryptographic key.

Depending on its current usability and validity, the **key** can be in various **states**, such as active, inactive, suspended, decommissioned, or expired.

- **Active:** The key is currently in use and available for cryptographic operations.
- **Inactive:** The key is not currently in use and is temporarily unavailable for cryptographic operations.
- **Suspended:** The key has been temporarily suspended due to security concerns or other reasons and is unavailable for cryptographic operations. Note: Suspension is temporary; revocation is permanent.
- **Decommissioned:** The key has been permanently retired and is no longer used for cryptographic operations.
- **Expired:** The key’s validity period has ended and is no longer available for cryptographic operations. A key that has exceeded its cryptoperiod for a specific use has expired for that use, but may still be used for other purposes (for which its cryptoperiod has not expired). For example, it is common for a key’s cryptoperiod to be a fraction of its cryptoperiod for decrypting data. In that case, it might be marked as ‘expired’ but still used to decrypt data that had been encrypted with it previously. Expired keys should still be available for decrypt, validate, unwrap operations to keep the system operational in case it uses some artifacts where this needs to be applied. They should not however, be used to encrypt, wrap, and signature as they are no longer considered valid/secure.

Key usage can also be considered a phase in the key management process when referring to the period during which the cryptographic key is actively used for cryptographic operations to secure data and communications. So key usage can also be related to the concept of a key’s cryptoperiod within the key management process.

During the key usage phase, the cryptographic key is employed for encrypting data, decrypting data, signing digital signatures, or performing other cryptographic operations (these are the asymmetric keys [such as public-private key pair], while the symmetric [serial] keys on the other side are used

solely for encrypting and decrypting data) as required by the applications and systems that rely on the key for security. As a best practice, a key should be used for only one purpose (for example, authentication, encryption/decryption, integrity, or signing). Using the same key for multiple cryptographic purposes may reduce the overall security and have a more significant impact if the key is compromised.

3.2.5 Key Backup/Recovery

Key backup is the process of backing up the encryption keys to secure storage with the same security controls and attributes as the primary storage. If encryption keys are lost, corrupted, or intentionally or unintentionally deleted, data encrypted with keys may not be recoverable. Therefore, backing up encryption keys is crucial in unlikely situations where keys may get corrupted or become inoperable. The key backup process is vital to the encryption key management strategy. Key backup storage must follow the same security requirements and guidelines as any other form of key storage. Key backup availability, integrity, and access controls are critical factors in determining the key backup strategy.

Key recovery refers to recovering the lost or corrupted encryption key in case encryption keys are deleted or become inoperable. If the encryption key is lost or corrupted, then the organization may be unable to recover the data if there are no means to recover the encryption or if key backup is unavailable. Hence, it is imperative to design appropriate solutions, strategies, and processes so that encryption keys are recoverable. However, in some situations, such as cryptographic erasure or crypto-shredding²³, where encryption keys will never be recoverable to ensure secure deletion of the data, key owners²⁴ must carefully assess which encryption keys will be recoverable.

One recovery method is to back up or archive the encryption keys. If the original key is lost or corrupted, the data owner or processor can get a copy from the key backup. For example, a key might be backed up to a smartcard or in the form of paper components that are stored securely in a different location.

Another method to backup or recover a key is **key escrow**.

Key Escrow is the process of storing keys with a trusted third party. If the original encryption key is lost, the escrow agent can provide the backup to decrypt and access the data. Another way is to regenerate or re-import keys from the key material (always depending on the specific key management system (KMS) or cryptographic system in use.)²⁵. Key escrow may also serve a similar

²³ Crypto-shredding involves the deliberate and irreversible destruction of the cryptographic material using specialized techniques. This ensures that even if remnants of the key exist in memory or storage, they are rendered unreadable and unusable. Some techniques, often used in combination to enhance the security of the crypto-shredding process are: cryptographic erasure, overwriting, physical destruction, zeroization, randomization, key splitting, etc.

²⁴ As per NIST, key owner is an entity authorized to use a cryptographic key or key pair and whose identifier is associated with a cryptographic key or key pair.

²⁵ In many secure systems, the master key is used to derive other keys through a process known as key derivation. This process typically involves using algorithms to transform the master key into different keys for various purposes, such as data encryption, authentication, and integrity. In cryptographic systems, the keys are derived from specific parameters or random values, and these parameters are crucial for the key generation process. Escrowing these parameters, rather than the actual keys, is a common practice for security reasons. **It is important to note that certain cryptographic principles**

purpose as code escrow²⁶. This practice provides an additional layer of security and resilience to key management processes. In situations where one party relies on the services or products of another party, and there is a concern about continuity in case the providing party faces financial issues, goes out of business, or faces other unforeseen circumstances, the use of escrow for both the application source code and the private key used for code signing is a risk mitigation strategy.

Circumstances during which key escrow may be required or recommended are:

- business continuity/disaster recovery,
- regulatory compliance, and
- long-term data retention.

Many cloud service providers (CSPs) provide automatic backups of encryption keys to multiple vaults²⁷. In addition, CSPs may have the option for the multi-region or zone keys for disaster recovery scenarios, or keys not available, deleted, or corrupted [11].

3.2.6 Key Revocation State

Key revocation is the process of transitioning keys from the active state to the inactive state before their cryptoperiod expires. While a revoked key is no longer considered valid, it is still technically usable. The period between revocation and inactivation provides a transition period during which new keys can be issued, and old data can be migrated to the new keys if necessary.

Triggers

Key revocation may be initiated for administrative reasons, such as when the key owner leaves the organization or when a device containing the key is taken out of service. In emergency situations, revocation may also be necessary if keys have been lost or there is a suspicion that unauthorized parties have gained access to them. In all cases, the revocation process should be carried out as promptly as possible, once the need for it has been identified.

Procedures

Procedures for revocation, including Certificate Revocation Lists (CRLs) and Compromised Key Lists (CKLs), must be effectively communicated to affected parties within and outside the organization to ensure that everyone involved in key management and security is aware of the processes. The procedures must be communicated to all affected parties. These include security teams responsible for implementing and managing the revocation processes and key administrators, individuals responsible for key administration and management within the organization. System administrators, those who manage the systems and applications that use cryptographic keys should also be informed about the procedures.

emphasize the irreversibility of key functions.

²⁶ Key escrow serves not only as a means of key recovery but can also have implications for business continuity and operational resilience. Keeping a copy of the encryption key in escrow, it ensures that the organization can maintain access to critical data even if the original key manager is no longer available or trustworthy. This concept aligns with the idea of code escrow, where access to source code is stored with a third party to mitigate risks associated with the original code provider.

²⁷ As part of the shared responsibility model, CSPs take some of the responsibilities of failover, redundancies, backups, etc. [12]

The procedures can be communicated via documentation (online preferred), training and education, meetings and workshops during initial onboarding, and refresher courses as procedures change. Communication can be made by the security team or security officer.

Overall, effective communication of revocation procedures is crucial to ensure that all relevant individuals and teams know how to handle revoked keys, update or access CRLs and CKLs, and transition to new keys when necessary. Clear, accessible documentation and regular training are essential to this communication process.

Notification

When a symmetric key is revoked, all entities that share the key must be notified. Typically revocation is recorded in a Compromised Key List (CKL) that is stored on a secure server or in a database with restricted access and maintained by the security team of the organization responsible for key management and security. This list is the basis for notifications pushed by the security team via secure email, messaging platforms, and dedicated messaging systems. While notifications are generally pushed²⁸ entities can be allowed to pull/check the status of keys by requesting information from the secure server or database if they have concerns, for example, that they have not been notified of a revocation. Revocation notifications should include complete identification of the key (excluding the key itself), the date and time of revocation, and the reason for revocation.

For asymmetric key pairs, revocation pertains to the private key. However, when public key certificates are used, the certificate containing the public key associated with the private key is revoked. Relying parties are notified using methods such as Certificate Revocation Lists (CRLs) or the Online Certificate Status Protocol (OCSP). The system can deliver notifications to all parties using the revoked key or by allowing entities to request the key's status (either through a "push" or a "pull" mechanism for obtaining status information). The notification should include complete identification of the key (excluding the key itself), the date and time of revocation, and the reason for revocation. Based on this information, other entities can determine how to handle information protected by the revoked key.

CKMS Security Policy

The CKMS Security Policy (SP) should specify the responsible organization(s), organization contact information, and any relevant statutory or administrative requirements for emergency and routine revocation and suspension of keying material (e.g., revocation due to a compromised key) and revocation requirements. The CKMS SP should either include or refer to guidelines for maintaining operational continuity and ensuring the security and integrity of the revocation and suspension processes. The CKMS Security Policy should also provide guidelines for maintaining revocation lists, emergency key and certificate replacement, and timely and reliable key and certificate establishment.

Record Keeping

All revocation activities and transactions should be logged (recorded) in the CKMS for operational, security, and compliance purposes.

²⁸ Notifications are typically delivered automatically, but there may be instances where entities can choose to pull or check the status manually.

3.2.7 Key Rotation

Key rotation involves rotating or updating the key periodically at the end of its cryptoperiod, or to reduce the potential impact of key-related risks. In the shared responsibility model, as discussed in **Section 2.2**, responsibility for key rotation depends on the key management architecture.

The primary objective of key rotation is to reinforce the system security by periodically updating cryptographic keys. This practice serves to minimize the susceptibility to security threats, particularly in the context of ciphertext-only scenarios, where repeated use of the same key may provide additional material for analysis. The decision to rotate keys is influenced by factors such as the encryption mode and algorithm, with a focus on mitigating risks associated with prolonged exposure of a key in specific cryptographic contexts.

The purpose of key rotation is to enhance the system's security and limit the potential impact of compromised keys. The key rotation process typically involves the following steps:

Frequency Determination: The organization's policy, based on its needs, perceived risks, etc., defines the frequency of key rotation based on security policies, industry best practices, and regulatory requirements. The rotation frequency may vary depending on the sensitivity of the protected data and the organization's risk assessment, which is outlined/included in the organization's policy description. All captured in the organization's policy description.

New Key Generation: A new cryptographic key is generated using a secure and approved random number generator (RNG)²⁹ or other appropriate methods before rotating a key. The new key can replace the current key in use, however in many cryptographic key management scenarios, adopting a versioning or re-labeling approach during key rotation is considered a best practice for reasons of transparency, operational understanding, compatibility, security posture, etc.

Key Distribution: The newly generated key is securely distributed to authorized users, applications, or systems needing access. This step ensures that all relevant parties can access the updated key and use it for encryption, decryption, or other cryptographic operations.

Key Activation: Once the new key is in place and distributed, it is activated for use, and the old key reaches the end of its intended lifecycle and expires. The activation process ensures the new key is operational and ready to serve its intended purpose.

Monitoring and Validation: Throughout the key rotation process, the organization monitors the status of the new key and validates its successful integration into the system [10]. The monitoring helps ensure a smooth transition and identifies any potential issues or errors.

Old Key Retirement: Once the new key has been successfully deployed and tested, the old key is retired from active use. The retirement process may involve securely archiving the old key for historical purposes or permanently deleting it, depending on the organization's data retention policies.

²⁹ Other aspects to be considered here along with the RNG are: the algorithmic strength, key length, RNG's entropy source, the periodic refresh, the cryptographic hardware, etc.

Repeat the Process: The key rotation process is an ongoing practice, and organizations repeat these steps regularly according to the defined rotation frequency. Regular key rotation ensures that cryptographic keys remain fresh and less susceptible to attacks over time.

Data Re-Encryption (Optional): In some cases, encrypted data using the old key may need to be re-encrypted using the new key to ensure continued security.³⁰ This step depends on the encryption scheme and the system's specific requirements.

As part of the key rotation phase, the organization may decide to modify the existing cryptographic keys. This involves changing the key attributes, access controls, validity period, or other key metadata without generating new keys. This procedure is called key update and can be considered a sub-phase of the key rotation phase which allows for more specific control over key attributes and permissions without generating entirely new keys.

Both key rotation and key updating are important security practices in key management, and the choice between them depends on the organization's security requirements, regulatory obligations, and the level of control needed over cryptographic keys. Some organizations may choose to regularly rotate their keys to maximize security, while others may prefer more detailed control through periodic key updating. This depends on the specific use case and the security posture of an organization as the two strategies can lead to different results.

3.2.8 Key Destruction

The key destruction process is an important part of the key lifecycle within a key management system (KMS). It involves securely and permanently removing cryptographic keys from the system to ensure they cannot be used for any further cryptographic operations. This process is initiated when keys are no longer needed, have reached the end of their lifecycle, or have been decommissioned. Here is a description of the key destruction process:

1. **Triggering Key Destruction:** Key destruction can be initiated for various reasons³¹, such as when a key reaches the end of its intended lifecycle, when it is compromised or suspected to be compromised, or when it is no longer needed due to changes in security requirements or regulatory compliance.
2. **Disabling Key Usage:** Before the actual destruction, the key is typically disabled or marked inactive to prevent further use. This step ensures that applications or services cannot perform any cryptographic operations using the key.
3. **Multiple Erasure Techniques:** Multiple erasure techniques may be employed to enhance security. These techniques can include overwriting the key material with random data, performing cryptographic erasure³². One of these techniques includes key recovery prevention as well³³.

30 In order to understand which keys are associated with specific data, an organization needs to establish a records system for data encryption labels, key rotation records, key metadata and usage logs, key labeling and documentation, etc.

31 These events are provisioned in the key management policy.

32 Please be aware of the potential circular dependency when it comes to operations like secure erasure, which requires using a key for encryption, and then the key itself needs to be securely destroyed. To achieve complete cryptographic independence for certain operations within a closed system additional measures are needed such as cryptographic splitting, 2-key systems, temporal separation, an external KMS or HSM that handles key destruction independently, etc.

33 Additional techniques include: cryptographic hashing, key splitting, cryptographic shredding, time-based destruction, etc.

4. **Secure Deletion:** The key destruction process involves securely erasing the key material from all storage locations³⁴, including memory, disk drives, and any backup systems. Secure erasure techniques ensure that the key cannot be recovered or reconstructed by any means.
5. **Key Revocation:** In some cases, it may be necessary to revoke or invalidate the key's usage or access instead of completely destroying it. Key revocation involves marking a key as invalid or no longer trustworthy. Revoked keys cannot be used for encryption or decryption, but their data may still be retained for historical or compliance purposes.
6. **Audit and Compliance:** Appropriate audit logs and records³⁵ should be maintained throughout the key destruction process to document the destruction event. This helps meet regulatory requirements and provides an audit trail for security and compliance purposes, as well as for internal policy reasons (e.g. accountability, quality control, documentation and compliance, process improvement, etc.).
7. **Confirmation and Verification:** Once the key destruction process is completed, it is important to verify and confirm that the key has been successfully destroyed and is no longer accessible. This can involve thorough testing, review of logs, and validation of the destruction procedures. [8]
8. **Documentation and Reporting:** Detailed documentation of the key destruction process should be maintained, including information such as the reason for destruction, the date and time of destruction³⁶, the individuals involved, and any relevant supporting evidence. This documentation can be used for reporting, compliance, and internal control purposes.

By following a robust key destruction process, organizations can ensure that cryptographic keys are securely and irreversibly removed from the system, minimizing the risk of unauthorized access or misuse. Properly managing key destruction is crucial for maintaining the security and integrity of sensitive data. Proof of the implemented key destruction process is provided through documentation, audit logs, compliance records, regular audits, security monitoring, etc.

34 The specifics of key storage can vary depending on the cryptographic systems and practices used within an organization. For critical applications and sensitive data, it's advisable to employ secure key management practices, including the use of dedicated key management systems and hardware security modules to enhance key security and control.

35 The verification of audit logs and records in the context of key destruction is typically part of an organization's overall audit and compliance processes. Some common practices for verifying key destruction include confirmation from key management system (KMS), tests conduction, checking cryptographic key databases or storage media, an independent party or team review the key destruction process and its verification steps, system functionality checks to confirm that the key is no longer recognized or accepted by the cryptographic systems, etc. Keep in mind that key destruction can be performed only by the key administrators. All destruction requests need to be reviewed within the safety window as a key cannot be destroyed immediately. It is disabled which prevents use and is deleted at the expiry of the window. During this period the user has the right to recover the deleted key, which is why some CSPs send the deleted item in the soft-deleted state, otherwise a purge operation is performed. [9]

36 The date and time of key destruction are typically provided in audit logs and records as part of key management practices.

4. Planning for Key Management Lifecycle Solution

It is important to understand the organization's unique requirements, threats and risks, and regulatory and compliance needs for key management solutions. Organizations may fall under various regulatory compliance regimes depending on the type of information they store and the industry guidelines they follow. Regulatory compliance helps businesses meet industry-specific guidelines. With increasing data use and storage risks, organizations must take stringent measures to ensure that sensitive information is kept safe from malicious agents. Most data security regulations require encryption key management as part of their compliance criteria. If these criteria are not met, businesses can be subject to fines, penalties, or worse.

Many standards (FedRAMP, PCI DSS) are based on the recommendations from NIST (National Institute of Standards and Technology) standards. Some of the regulatory compliance regimes and/or standards that ensure the proper encryption and protection of data are listed in the table below:

NIST	NIST (National Institute of Standards and Technology) NIST 800:53 Security and Privacy Controls for Information Systems and Organizations NIST SP 800-52 "Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Applications" NIST SP 800-57 "Recommendation for Key Management" NIST SP 800-171 "Cyber Security Framework" or NIST CSF consists of standards, guidelines, and best practices that help organizations improve their management of cybersecurity risk
FedRAMP	Federal Risk and Authorization Management Program (FedRAMP) relies on several of the NIST SP documents, including 800-53 as a library of system controls and 800-37 for risk management. The streamlining occurs with a focus on which controls the CSP manages and which are managed by the agency purchasing the cloud services. SC-12: Cryptographic Key Establishment and Management SC-12(1): Maintain availability of information in the event of the loss of cryptographic keys by users. SC-12(2): Produce, control, and distribute symmetric cryptographic keys using FIPS validated key management technology and processes. SC-12(3): Produce, control, and distribute asymmetric cryptographic keys SC-12 (6): Maintain physical control of cryptographic keys when stored information is encrypted by external service providers. SC-13: Cryptographic Protection SC-17: Public Key Infrastructure Certificates.

FIPS	Federal Information Processing Standard (FIPS) 140-2 FIPS 140-3 is a government standard specifying security requirements for cryptographic modules, including hardware and software components. These security requirements are designed to ensure that cryptographic modules provide a minimum level of security for protecting sensitive information and transactions
PCI DSS	Payment Card Industry Data Security Standard (PCI DSS) PCI DSS Requirement 2.3: Encrypt all non-console management access using strong encryption. PCI DSS Requirement 3.5.1: There should be a documented description of the cryptographic architecture detailing all algorithms, protocols, and keys used to protect cardholder data, including key strength, expiration date, and a description of the function of each key. PCI DSS Requirement 3.6: All key management processes and procedures for cryptographic keys used to encrypt cardholder data should be fully documented and implemented. PCI DSS Requirement 3.6.1 requires organizations to generate strong encryption keys. The PCI DSS standard does not address exactly how to achieve strong encryption, thus making it a daunting task. PCI DSS Requirement 3.6.2 focuses on the secure distribution of cryptographic keys. As indicated in the access list, keys should be distributed to selected custodians, which should not be in large numbers. PCI DSS requirement 9 requires the management of privileged access rights, and official documentation is reviewed to determine the proper management of elevated privileges. After the analysis is complete, an auditor will check the keys to be distributed to the correct administrators.
ISO 27001	ISO 27001:2022 A 8.24 Use of cryptography ISO 27001:2022 Annex A Control 8.24 enables organizations to maintain the confidentiality, integrity, authenticity, and availability of information assets by properly implementing cryptographic techniques and by considering business needs, information security requirements, and statutory, contractual, and organizational requirements concerning the use of cryptography. ISO 27001 - Annex A.10 - Cryptography ISO/IEC 19790:2012 - Security Requirements for Cryptographic Modules ISO 24759:2017 - Test Requirements for Cryptographic Modules

GDPR	EU's GDPR (General Data Protection Regulation) for protecting users' personal data. Encryption as a concept is explicitly mentioned as one possible technical and organizational measure to secure data in the list of Art. 32(1) of the GDPR, which is not exhaustive. To answer the question of what is currently considered "state of the art," data protection officers usually rely on the definitions set out in information security standards like ISO/IEC 27001 or other national IT security guidelines.
HIPAA	Health care industry's Health Insurance Portability and Accountability Act (HIPAA) for protecting patient data.
Common Criteria	Common Criteria is an international standard designed to unify national IT security throughout the US, Canada, the UK, France, Germany, Australia, and New Zealand. 6.1 Security Requirements 6.1.1 Key management 6.1.1.1 Management of security attributes 6.1.1.2 Hash-based functions 6.1.1.3 Management of certificates 6.1.1.4 Key generation, agreement and destruction 6.1.1.5 Key import and export 6.1.2 Data encryption 6.1.3 Hybrid encryption with MAC for user data 6.1.4 Data integrity mechanisms 6.1.5 Authentication and attestation of the TOE, trusted channel

To meet regulatory compliance requirements and to provide the highest level of data security, HSMs provide all the encryption functionality, user access, and in many cases, key management software. They are resistant to tampering and help secure encryption. A hardware security module (HSM) is a physical device that provides extra security for sensitive data that is used to provision cryptographic keys for critical functions such as encryption, decryption, and authentication for the use of applications, identities, and databases. HSMs provide the centralized key generation, management, and storage that businesses need, as well as authentication and digital signing capabilities. HSM technology has proven to have the flexibility needed to keep up with the move to the cloud and the increasing threat environment organizations face today.

The United States Federal Information Processing Standard (FIPS-140) standard defines approved cryptographic algorithms and sets forth requirements for key generation and key management. The organizations use HSM to achieve operational agility and regulatory compliance. More specialized HSMs must comply with various standards and regulations, including the following:

GDPR	(General Data Protection Regulation) is a European Union regulation with stringent laws to protect private data, and companies failing to do so face severe penalties.
PCI DSS	PCI DSS (Payment Card Industry Data Security Standard): Applicable for financial and banking organizations, neo banks, and crypto institutions that handle payment cardholder data.
FIPS 140-2	FIPS 140-2 (Federal Information Processing Standard): A US government standard for encryption algorithms and cryptographic modules to ensure the confidentiality and integrity of sensitive data.
ISO/IEC 27001	ISO/IEC 27001 is an international standard for Information Security Management Systems (ISMS). It includes guidelines for risk assessment and management, security controls and procedures, and regular review and evaluation of the ISMS.
SOC 2	SOC 2 (Service Organization Control 2) is a security audit that assures the security and privacy controls of the service provider are as per the required standards.
Common Criteria	Common Criteria is an international standard (ISO 15408) to test and evaluate an HSM against specific requirements.

4.1 Technical Considerations

Before planning for a key management lifecycle solution, it is essential to understand the technical considerations that come with it. Many cryptographic algorithms require unique keys that must be kept secret from unauthorized users. Managing these keys throughout their lifecycle is a challenge. Therefore, it is important to understand the technical properties of cryptography and key management to develop a reliable key management system.

The following steps should be considered:

- Identify how to generate keys effectively to prevent them from being predictable. One way to generate keys is by using a random number generator. However, not all random number generators are created equal. Some are more predictable than others, which can lead to weak keys. Therefore, using a high-quality random number generator to generate keys is essential. In addition to choosing a strong random generator, it is essential to consider its required level of entropy. For instance, generators base their entropy on human interaction, which is inherently limited in cloud and containerized environments. In some cases, generators cannot be used immediately after the operating system starts up since they have some running time, so they can gather enough entropy.
- Assess the encryption algorithms and key sizes before planning to use them. Some encryption algorithms are more secure than others, and some key sizes are more robust. Therefore, the most suitable encryption algorithm and key size combination that meets specific security requirements should be chosen.
- Select the correct encryption algorithm and key size and consider how to store the keys efficiently. Keeping keys in plain text is not secure, as anyone accessing the storage

medium can read the keys. Therefore, secure storage mechanisms, such as hardware security modules, smart cards, or trusted platform modules, should be used to store the keys. Sometimes, additional keys are required to provide a more robust and durable key lifecycle. These keys are referred to as wrapping or key encryption keys (KEK), and they are widely used in data encryption at rest. A wrapper or envelope key provides additional security when exporting and transporting sensitive keys.

- Improve the security of the cryptosystem. One way to do this is by renewing the key periodically. The key renewal process should be considered in the key generation process. For instance, symmetric keys typically have an attribute indicating their expiration date, and consumers should normally reject expired ones. When rotating keys, it is crucial to decommission old keys in a way that they can no longer be used for future operations but are safely backed up in the case it is required to deal with previously encrypted data.
- Employ multiple regions and availability zones to improve availability and fulfill disaster and recovery requirements for cloud-based systems. The key management should be considered in this approach. For instance, different environments should have different key materials so that the outages caused by keys are mitigated by migration from the active to the backup environment.
- Designing a key management strategy to define the purpose of the keys and the consumers' capabilities is important. While cloud-based key management systems (KMS) often provide functionalities to consume keys without needing to export and expose them to a less secure environment, some consumer applications integrate well with such KMS functionalities and still require access to the keys. In such cases, it is required to provide a secure means to export keys into the application's environment and securely delete key materials when the operation is complete. Such activities become crucial in shared infrastructure environments.
- Consider how to safeguard and recover the keys in case of loss or damage. Losing a key can be catastrophic, as it can render the encrypted data unreadable. Therefore, it is necessary to have a robust key backup and recovery mechanism in place. This can include storing backup copies of the keys in secure locations, using key escrow services, or implementing a key recovery process.
- KMS should provide the functionality to label (tags, metadata, etc.) the keys to help identification, inventory management, processes, and procedures.
- Consider secure transport mechanisms while accessing the KMS and keys. For example, KMS should use the latest TLS (Transport Layer Security) to access the keys.
- KMS should be able to integrate and enforce a granular IAM access model and follow the principle of least privilege access.
- KMS should have capabilities to enforce granular network access control mechanisms to limit access to KMS and Keys.
- Integration with other required systems (such as asset management and CMDB) should be available.
- Logging, monitoring, and reporting should be available in the KMS solution to ensure the organization can monitor and audit the key security and usage.

4.2 Operational Considerations

When managing keys on-premises, one of the most important considerations is physical security. Organizations need to ensure that the place where they keep their key management systems is secure using measures like locked server rooms, surveillance systems, and access controls to limit access to authorized personnel only.

Hardware Security Modules (HSMs) can also be used to store and handle cryptographic keys securely. They provide an extra layer of protection to ensure the keys are safe. It is also essential to have secure communication channels in place to protect data when it is being transferred, which can be done by using encryption protocols like TLS or IPsec. Organizations should ensure the availability of the key management systems, redundancy, and disaster recovery mechanisms via backup systems and redundant hardware or failover configurations. Regularly backing up cryptographic keys and storing them securely off-site is crucial to prevent data loss in case of hardware failures or natural disasters. Lastly, access controls play a significant role in ensuring that only authorized individuals can access and manage the keys. This involves using strong authentication methods, robust passwords, role-based access controls (RBAC), and comprehensive auditing capabilities to track who has access to the keys and what they do with them.

Organizations can take advantage of the key management services offered by multiple cloud service providers like AWS, Azure, or Google Cloud. These services provide built-in capabilities for managing keys within the cloud environments. Maintaining key isolation is crucial when using multiple cloud environments. It means keeping the keys separate within each cloud environment to prevent any unauthorized access or attacks due to a breach. Key isolation can be achieved through separate instances or logical key separation mechanisms. Interoperability and portability are also important considerations in multi-cloud environments because they can ensure the keys can work seamlessly across different cloud platforms and allows for the secure transfer of keys and associated data between different clouds.

On both on-premises and (multi-)cloud-based environments, it is crucial to have a key incident response plan in place to minimize the damage and time to recover from compromised keys. A cryptographic key management incident response plan is a comprehensive strategy designed to address and mitigate any security incidents or breaches related to cryptographic keys. This plan includes identifying and containing the incident, assessing the impact, recovering or revoking compromised keys, and restoring normal operations. It outlines the processes, protocols, and procedures to be followed when an incident occurs, such as the compromise, loss, or unauthorized access of cryptographic keys. A robust incident response plan helps organizations minimize the impact of key-related incidents and protect sensitive information.

4.3 Financial Considerations

4.3.1 Financial Considerations for On-Premises and Multi-Cloud

For financial considerations regarding key management in the public cloud, it is important to pay attention to the many add-on costs that organizations could incur. Most cloud providers publish these online so that organizations can evaluate the differences. In addition to published prices, most service providers have calculators online, which allow the input of different scenarios. Each cloud provider charges a per key fee, but it is not the only cost. Add-ons such as costs per operation, certificate renewal, key rotation, and more accumulate on a bill. Some service providers have free tiers where key requests/ operations costs can be free up to a certain amount. Hardware security modules can come with a hefty up-front charge due to incurring data transfer and hourly charges. It is necessary to consider which region is being used as different regions have different costs.

It is the same with on-premises solutions, where the charges can differ by environment. When reviewing internal estate (on-premises keys) for key costs, this is important.

When planning for a key management lifecycle solution, whether for on-premises or multi-cloud environments, there are several financial considerations that organizations need to take into account:

Initial Setup Costs:

- On-Premises: Setting up an on-premises key management solution may involve substantial upfront costs, including hardware, software licenses, and professional services for installation and configuration.
- Multi-Cloud: Multi-cloud environments may require initial setup costs for cloud-based key management services, such as provisioning cloud resources and configuring security policies.

Operating Expenses:

- On-Premises: Organizations need to consider ongoing operating expenses, including hardware maintenance, software updates, and staffing for system administration.
- Multi-Cloud: Operating expenses in multi-cloud environments may include subscription fees for cloud-based key management services and operational costs associated with cloud resources.

Scalability Costs:

- On-Premises: Scaling an on-premises key management solution often involves additional hardware and infrastructure costs as the organization grows.
- Multi-Cloud: Multi-cloud solutions can provide scalability benefits, but organizations should be aware of potential increased costs as usage of cloud resources increases.

Vendor Lock-In:

- On-Premises: While on-premises solutions offer control and independence, they may also entail vendor lock-in if the organization relies on proprietary hardware or software.
- Multi-Cloud: Multi-cloud environments offer flexibility but can lead to vendor lock-in if organizations become highly dependent on a particular cloud provider's key management services.

Data Transfer Costs:

- On-Premises: Data transfer costs between on-premises data centers and cloud services

should be considered, as they can add to the overall expenses.

- Multi-Cloud: When using multiple cloud providers, inter-cloud data transfer costs may apply and should be included in the budget.

Compliance and Regulatory Costs:

- On-Premises: Meeting compliance and regulatory requirements for on-premises key management may involve auditing and reporting costs.
- Multi-Cloud: Multi-cloud environments may require additional compliance efforts, including compliance with various cloud providers' security standards.

Disaster Recovery and Redundancy:

- On-Premises: Implementing disaster recovery and redundancy measures for on-premises solutions can be costly but is essential for data resilience.
- Multi-Cloud: Multi-cloud solutions may offer built-in redundancy, but organizations should assess the costs associated with data replication and failover across multiple clouds.

Training and Skill Development:

- On-Premises: Training staff for on-premises key management systems is necessary, and the associated costs should be considered.
- Multi-Cloud: Multi-cloud environments may require training to ensure staff can effectively manage and secure keys across different cloud platforms.

Total Cost of Ownership (TCO) Analysis:

- Conducting a comprehensive TCO analysis is essential to compare the long-term costs of on-premises and multi-cloud key management solutions, factoring in all relevant financial considerations.

Economic Models:

- Evaluate different economic models, such as pay-as-you-go, subscription-based, or perpetual licensing, depending on the chosen key management solution and deployment model.

ROI and Business Value:

- Assess the return on investment (ROI) and the business value derived from the key management solution to determine if it aligns with the organization's strategic goals.

Financial considerations play a crucial role in determining the most cost-effective and suitable key management lifecycle solution for an organization's specific needs, taking into account its infrastructure, compliance requirements, scalability, and long-term objectives.

4.4 Recommended Best Practices

4.4.1 Recommended Best Practices for On-Premises and Multi-Cloud

- **Tailored Environments for Control and Flexibility**
Initiating the planning phase for a key management lifecycle solution necessitates considering best practices suited for both on-premises and multi-cloud environments. On-premises solutions grant organizations comprehensive control over their key management infrastructure. Conversely, multi-cloud solutions offer scalability and flexibility while retaining key management control.
- **Alignment with Organizational Needs**
A paramount aspect of planning a key management lifecycle solution is ensuring alignment with the organization's unique requirements. Organizations must meticulously weigh factors such as organization size, data sensitivity, and industry-specific regulatory obligations. Opting for a key management solution that accommodates scalability, robust security measures, regulatory compliance, and user-friendliness is imperative.
- **Encryption Standards and Compliance**
Key management solutions should be evaluated based on their encryption levels, with a keen eye on adhering to relevant key management standards. Specific industries like healthcare and finance have stringent regulatory mandates for key management. Implementing more robust encryption safeguards data against unauthorized access and ensures compliance with industry-specific regulations.
- **Seamless Integration and User-Friendliness**
A key management solution's ease of integration and user-friendliness are pivotal considerations. The chosen solution should seamlessly integrate into existing infrastructure, facilitating rapid deployment and straightforward utilization. This streamlined approach accelerates the protection of sensitive data.
- **Human Elements and Training**
Beyond the technical aspects, key management success hinges on the human element. Adequate employee training is crucial to ensure the proper use of the solution. Staff should understand the significance of key management in safeguarding the organization's sensitive data. This comprehensive approach fortifies the organization against data breaches and security threats.

By incorporating these enhanced best practices recommendations, organizations can navigate the complexities of planning for a robust key management lifecycle solution tailored to their needs and industry requirements.

4.4.2 Best Practices for Implementing a Key Management Lifecycle Solution

Implementing a robust key management system (KMS) is a substantial undertaking, but with careful planning and execution, it can be a seamless process. Here are best practice recommendations to guide and organization through the successful deployment of a KMS:

Begin with a Pilot Project:

- Start with a pilot project to test the KMS solution's functionality and verify that it aligns with your organization's requirements and objectives.

Identify Key Stakeholders and IT Personnel:

- Identify key stakeholders and IT personnel involved in the KMS implementation.
- Ensure that all relevant individuals are trained in using the KMS effectively.
- Develop a communication plan to articulate the changes that will occur and the rationale behind them.

Comprehensive Testing during the Pilot Phase:

- During the pilot phase, encrypt data, perform secure key transfers, and closely monitor key usage.
- Evaluate the integration of the KMS with the existing infrastructure to identify and address any issues or areas for improvement.

Scaling Up the Implementation:

- After completing the pilot project, proceed to implement the KMS on a broader scale.
- Collaborate with IT personnel to seamlessly integrate the KMS into existing systems and workflows.
- Ensure that all relevant stakeholders are informed about the changes being introduced.

Continuous Monitoring and Adaptation:

- Implement continuous monitoring practices to maintain the effectiveness of the KMS.
- Conduct regular security assessments to identify vulnerabilities and address them promptly.
- Review usage logs and performance metrics to detect anomalies or irregularities.
- Update policies and procedures to meet evolving security needs and compliance requirements.

Iterative Improvement:

- Embrace an iterative approach to refining the KMS implementation.
- Solicit feedback from users and stakeholders to gather insights for enhancements.
- Continuously assess the KMS against changing threats and organizational needs.

Key management system deployment and management requires careful planning, precise execution, and ongoing vigilance. Following these best practices will empower an organization to safeguard its data effectively and defend against potential security threats.

5. Deployment of Key Management Lifecycle Solution

Efficient deployment strategies are essential to manage cryptographic keys effectively. One way to do this is to use hardware-based HSMs, which can be deployed on-premises, in the cloud, in a hybrid environment, or as HSM-as-a-Service solutions. Another option is to use software-based HSM, which includes deployment options such as cloud-native KMS and open SSL software-based HSMs.

5.1 Deployment Approaches

5.1.1 Hardware-Based HSM Deployment Approach

Hardware-Based HSM Overview

Generating keys through a hardware-based method involves using a physical HSM module. Customers perform all key management activities in this approach, including management of the physical module. This deployment method is ideal for situations that demand strict control over key lifecycle phases and require control over physical access to the HSM module. It is especially crucial in cases where regulatory requirements exist for example, generating keys that comply with FIPS 140 level 3 or higher.

[Please check this CSA reference guide for more information related to the implementation approach.](#)

5.1.1.1 Deployment Approach for HSM

On-Premises: In this approach, customers are responsible for supervising all significant management obligations. It is crucial to establish operational processes and segregation of responsibilities for technical procedures such as key creation, key distribution, or more, and administrative duties such as (HSM maintenance, physical security, device updates, or any administrative activities). Doing so will ensure that these key management tasks are performed securely.

Advantages: The customer manages a robust random number generator with high entropy and controls the device and key management.

Concerns: The costs associated with maintaining and ensuring availability/redundancy may be relatively high.

An organization using on-premises deployment should consider the following aspects:

Data Sovereignty and Residency Requirements: Some regions and countries, such as the European Union, are stringent on data residency regulations, cross-border data movement, and data

sovereignty requirements. The ability to keep the encryption keys, an encryption engine and to perform the encryption function on-premises makes it easy for the organizations to meet those data residency and sovereignty requirements.

Latency and Performance: On-premises deployments offer some performance advantages compared to roundtrips and latency impact in cloud deployment; on-premises KMS offers the lowest latency and superior performance unless there are any configuration or other issues.

Maintenance and Patching: Like any other data center equipment, the hardware, and software hosting KMS in the data center need periodic maintenance of high or critical vulnerability patching following all the organizational change management processes.

Support Staff: Organizations must plan for the right support staff to manage the KMS in the corporate data centers.

Deployment in the Cloud

With this approach, the customer is accountable for implementing and overseeing the solution in the cloud. The cloud service provider (CSP) is responsible for physical HSM hardware implementation, support, and integration. The CSP provides HSM deployment as Infrastructure-as-a-Service (IaaS). The customer must also ensure that the cloud applications are appropriately connected with necessary networking, identity, and other components to enable KSM activity.

Advantages: The customer manages a robust random number generator with high entropy and all the cryptographic operations. CSP handles physical HSM device management overhead. In this approach, customers have options to build a scalable solution.

Concerns: This approach has key operations management overhead and HSM physical device is under cloud provider control.

Hybrid Environment

In this approach, the customer has KMS workloads running both on-premises and in the cloud. The hybrid deployment approach enables using a physical HSM device in either location or both to manage KSM activities. The customer is responsible for maintaining all networking (if on-premises) and access management activities.

Advantages: The customer manages a robust random number generator with high entropy, and the customer manages all the cryptographic operations. Customers have the option to build on scalable solutions.

Concerns: This approach has key operations management overhead for on-premises HSM; the physical device is under cloud provider control for cloud HSM deployments.

HSM-as-a-Service Mode

In this model, the HSM service provider provides the service to customers. The customers are responsible for managing identities, access controls, and ensuring security when consuming the service. HSM service providers will provide the functionality to handle key management aspects such as generating keys, distributing keys, key rotation, and more, via APIs or UI (user interface).

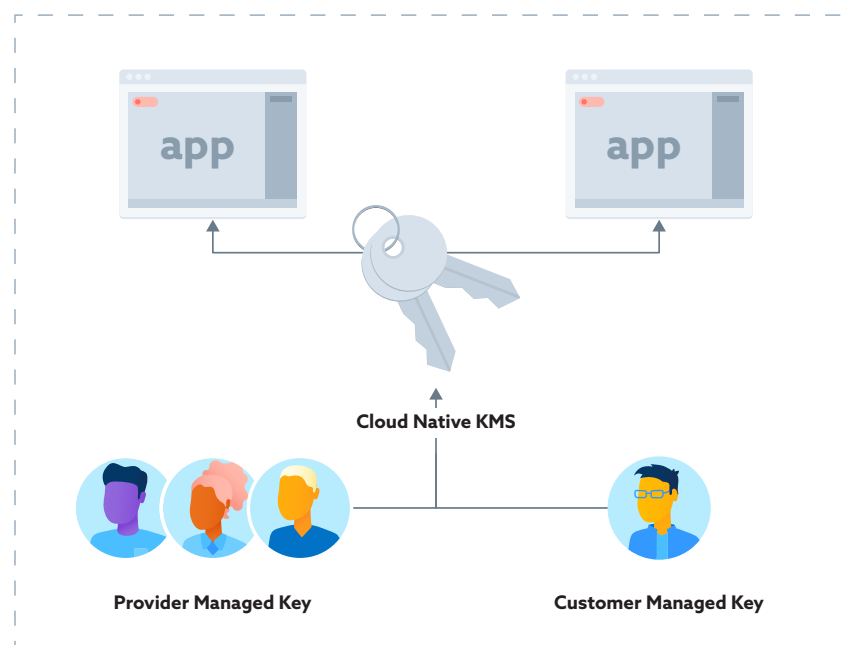
Advantages: The customer manages a robust random number generator with high entropy and the HSM service provider efficiently manages all cryptographic operations, ensuring seamless application integration using APIs. The CSP handles physical HSM device management overhead.

Concerns: Multi-tenancy, side channel attacks, and supply chain risks are principal concerns.

5.1.2 Software-Based HSM Overview Deployment Approach

Software-Based HSM Overview

Creating keys with a software-based HSM requires trusted computing devices or software like OpenSSL to manage cryptographic operations. Software-based HSMs may have options for cloud service provider keys, or customer-managed keys, or they may support both. However, software-based HSMs have limitations. For example, their random number generator may lack entropy compared to hardware-based HSMs. Nonetheless, they can still provide sufficient security for most organizations and data types, except sensitive data types governed under specific regulations that warrant physical HSM. However, it is important to note that software-based HSMs are certified to FIPS 140-2/140-3 Level 1.1.



Deploying Key Management in Cloud

Please check this CSA reference guide ([Recommendations for Adopting a Cloud-Native Key Management Service](#)) for more information related to the implementation approach.

Deployment Approach for Software-Based HSM with Cloud Service Provider Keys

The cloud service provider manages the key management service (KMS) in this approach, including importing the key material. It is known as cloud service provider-managed encryption, where the CSP handles cryptographic operations like (key rotation). However, the customer is responsible for correctly referencing keys in applications and access management.

Advantages: The integrations between the same CSP applications are flexible, and easy to manage.

Concerns: Multi-tenancy, side channel attacks and supply chain risks.

Deployment Approach for Software-Based HSM with Customer Managed Keys

In this approach, the cloud service provider manages the Key Management Service (KMS), and the customer imports key material. The CSP handles cryptographic operations like (key rotation). However, the customer is responsible for correctly referencing keys in applications and access management.

Advantages: The integrations are flexible between the same CSP applications. It is more secure than using provider-managed keys.

Concerns: Multi-tenancy, side channel attacks, supply chain risks.

5.2 Deployment Considerations

Organizations should prioritize confidentiality, integrity, and availability to ensure the secure deployment of key lifecycle management solutions. Provided below are some of the key technical considerations that organizations should take into account:

Identity and Access Management:

Identity and access management is crucial for secure deployment and operation. The least privileged access model should be used, and RBAC (Role Based Access Control) permissions should be granted for specific key operations. For example, administrative accounts should have access to generate keys, and applications should have access to perform key get and list functions. Maintaining a role-based access approach by clearly defining specific functions and responsibilities is crucial. It ensures access privileges align with individual roles and prevents unauthorized access to sensitive key operations.

Example: The RACI table that follows is provided as an example. An organization should establish a key lifecycle operation RACI model as per their organizational structure.

Key life cycle operation	Description	Responsible	Accountable	Consulted	Informed
Key Generation	Creating new cryptographic keys based on established policies and requirements.	Security Team	Security Team	IT Manager	Key Users, Management
Key Distribution	Safely delivering cryptographic keys to authorized users or systems while maintaining security and compliance.	IT Team	IT Manager	Security Team, Legal	Key Users
Key Storage	Securely storing cryptographic keys to prevent unauthorized access and potential breaches.	Security Team	Security Lead	IT Manager	Key Users, Compliance
Key Usage	Utilizing cryptographic keys for encryption, decryption, or authentication purposes within authorized applications or processes.	IT Team	Security Team	Application Team	Management, Compliance
Key Backup and Recovery	Creating and maintaining backups of cryptographic keys to ensure data can be recovered in case of key loss or system failure.	Security Team	Security Lead	Legal	Key Users, Compliance
Key Revocation	Invalidating and rendering cryptographic keys unusable when they are compromised, obsolete, or no longer needed.	IT Team	IT Manager	Security Team	Key Users, Compliance

Key Rotation	Regularly updating cryptographic keys with new ones to enhance security and reduce the impact of potential breaches.	Security Team	Security Lead	IT Manager, Compliance	Management
Key Destruction and Disposal	Properly disposing of cryptographic keys that are no longer needed, ensuring they cannot be retrieved or used maliciously.	Security Team	Security Lead	IT Manager	IT Manager

Auditing:

Maintaining a detailed log of all operations is critical, particularly when utilizing a HSM. HSM logs should be securely preserved according to the specified retention requirements. It is crucial to forward all logging information to the SIEM (Security Information and Event Management) solution to facilitate security monitoring activities. The key management solution should adhere to standards such as PCI DSS, HIPAA, GDPR, or any other applicable regulations. These standards include requirements such as audit trails for key rotation and secure storage of cryptographic material. Auditing features to track key usage, changes, and compliance with established policies should be enabled to help identify and respond to any security incidents or policy violations. **See section 5.4.**

Network Security:

Encrypting all communication and employing the latest TLS versions to guarantee secure network traffic between users, applications, or any services accessing the KMS systems is essential. It ensures that the network traffic remains protected and maintains high security. The organization should ensure that the solution complies with industry-standard encryption algorithms and protocols. Organizations can implement encryption algorithms such as AES (Advanced Encryption Standard) or RSA (Rivest-Shamir-Adleman).

Integrations and Protocols:

KMIP (Key Management Interoperability Protocol):

The organizations should evaluate how the key management solution integrates with the existing infrastructure and applications and consider compatibility with popular cryptographic standards and protocols to ensure interoperability. Utilizing the KMIP protocol is recommended to integrate application systems and key management operations securely. KMIP is a flexible communication protocol that defines standardized message formats for handling cryptographic keys on a key management server. This protocol simplifies encryption key management, facilitating streamlined data encryption procedures. It supports APIs or SDKs (Software Development Kits) for easy integration with applications and systems.

Availability:

When an organization is designing and implementing key management systems (KMS), it is crucial to prioritize availability. The downtime of KMS systems can significantly affect downstream applications that rely on cryptographic operations. Therefore, the design and implementation of KMS should focus on incorporating high redundancy and multi-regional failover capabilities. Additionally, it is essential to have a robust disaster recovery plan in place to ensure uninterrupted access to key management services, even in the event of failures or disruptions. Organizations should consider backup and replication strategies for keys and cryptographic material to implement a disaster recovery strategy to mitigate the risk of data loss or service disruption.

Scalability

Organizations should plan for scalability to accommodate future growth and increased demands for cryptographic services. The key management solution should meet the need and be scalable for a growing number of keys, users, and applications without compromising performance or security. A distributed key management architecture that can take many keys and concurrent requests should be deployed. Organizations should utilize load-balancing techniques to distribute key management operations across multiple servers. They should consider horizontal scaling by adding more key management servers as the workload increases.

Security Review:

Conducting a thorough threat analysis on the design and implementation architecture of hardware security modules (HSMs) is imperative to achieve integration between application systems and key management operations. This analysis involves examining potential attack vectors to identify vulnerabilities and risks. By conducting such assessments, organizations can implement appropriate security controls, incident response mechanisms, and other best practices to mitigate potential threats effectively. Regularly updating and patching the key management solution is important to address security vulnerabilities.

Trusted Computing:

Employing trusted computing hardware to ensure the confidentiality and integrity of KMS cycle operations is crucial. One practical example of this is the integration of trusted platform modules (TPM), which effectively contribute to the system's overall security.

Testing and validation:

The organization should thoroughly test the key management solution before deployment to ensure its functionality, security, and compatibility with its specific environment. Periodic audits and vulnerability assessments to validate the ongoing protection of the solution should be conducted. In addition penetration testing and vulnerability assessments to identify and address any security weaknesses should be performed. The organization should conduct performance testing to identify and address any bottlenecks or performance issues, and validate the solution against industry standards and best practices, such as NIST SP 800-57 or FIPS 140-22.

5.3 Operations and Maintenance

Change management processes, including version control, should be established to handle updates and changes to the solutions, ensuring proper testing and implementation. Developing a comprehensive change management plan that clearly outlines the deployment activities, timelines, and required resources is crucial. Defining the roles and responsibilities of the change management team and other stakeholders involved is essential for effective communication and coordination.

System compatibility, scalability, integration, and security requirements should be carefully considered during planning. Before deploying the key management solutions organization-wide, conducting pilot or small-scale deployments in selected areas allows for gathering feedback, identifying areas for improvement, and making necessary adjustments. Thorough testing must be performed to ensure proper functionality and seamless integration with existing systems. Establishing change control processes enables effective management and tracking of deployment-related changes, while documenting configuration settings, version control, and customizations serves as a valuable reference for future troubleshooting and maintaining consistency.

5.4 Auditing Requirements

Key audits are conducted periodically or as needed throughout the entire key lifecycle to assess the effectiveness and compliance of key management practices. Audit processes are essential for monitoring, governance, accountability, and regulatory compliance. The strength of cryptographic keys to perform their desired function rests entirely on the assurance of their confidentiality and integrity; thus, if assurance cannot be provided for keys, systems, and processes providing these controls, the underlying cryptosystem may not be trusted. Furthermore, where these activities and subsequent incident response/investigation may identify compromised keys or other suspicious activities, this may result in key revocation and destruction.

Audits may also be performed as part of the forensic investigation if a key (or underlying data) is suspected of compromise. The timing and urgency of these activities will vary, but the underlying artifacts and activities may be very similar.

The encryption key audit process that exists entirely or in part within cloud-based systems can be complicated. The following practices may help facilitate the auditing of keys and key management activities:

1. **Compliance:** Before establishing key audit activities, the organization should assess relevant regulations or compliance requirements governing key management. These considerations will shape the audit requirements for keys, determining monitoring criteria, log contents, audit frequency, and the specific audit activities necessary to ensure compliance.
2. **Logging:** In the context of key audit activities, the organization must address logging requirements specifically. This involves considering regulations or compliance standards

that influence the audit criteria for key management. Organizations need to define appropriate monitoring requirements, specify log contents, determine audit frequency, and outline necessary audit tasks to maintain robust logging practices.

- a. **Log Source:** All cloud KMS systems should support logging, either within the KMS platform itself or to separate cloud services relied upon to perform this task. Furthermore, where KMS systems do not have knowledge of the underlying purpose, activities, entities, or origin of activities, logs may be required from other systems, such as the application that utilizes the keys or the remote access solution that enables access to the KMS. Care should be taken to ensure a reliable correlation of logs from multiple sources, especially when these activities occur in disparate systems or during high transaction volume.
- b. **Logged Activities:** All key management activities that result in changes or movements of keys must be logged. These include key generation, key loading, key backup / recovery, key distribution, key revocation / rotation, and key destruction. It is necessary only sometimes to log the usage of low-level keys except to demonstrate that such keys are used per their designated usage. However, architects should check with policy and compliance requirements before determining whether these activities must be logged.
- c. **Log Contents:** The audit trail provided by logs must provide useful information for auditors and investigators to discover the potential gaps in procedures or sources of illicit key access or use. As such, key management logs should contain a minimum of the following:
 - i. Unique identifier of the key or keys being acted upon;
 - ii. Checksum, hash, signature, or other information related to the integrity of the key;
 - iii. The performed activities
 - iv. Unique identifier for the user, system, application, and process that acted upon the key;
 - v. Location information related to the retrieval or storage of the key (e.g., HSM identifier, sending/receiving system(s));
 - vi. Date and time of activity;
 - vii. Information about the activity's success, failure, or result; and
 - viii. Metadata that allows the log to be further correlated with other records, such as session ID, token, and ticket number
- d. **Log Integrity and Retention:** The systems performing the activity, log storage volume, and logs themselves must be protected from unauthorized access or modification and be retained for sufficient time to ensure such review is successful at reconstructing the nature of key management activities occurring over a time and months or even years after the activity. Bad actors who intent to manipulate or misuse keys will want to cover their tracks, so they may attempt to modify or delete the logs containing their activities. Organizations should use IAM, network ACLs, FIM, and other security controls to ensure these logs' integrity. Many compliance frameworks require specific protections for systems performing, storing, and reviewing these logs.

- e. **Log Monitoring:** A periodic review of logs is necessary to identify gaps and deviations from established standards, policies, and procedures.

3. **Preparation:**

- a. **Architecture:** It is important that the cloud KMS architecture design considers the logging requirements of the systems performing each function
- b. **Documentation:** Standards, policies, and procedure documentation that describes all about them should be enabled for all key management activities that include the identity of the person, process, or system performing the task.
 - i. It is crucial to provide documentation of the process used to generate encryption keys, including details such as key length, algorithms, and used random generators.
 - ii. An explicit and detailed definition of roles and responsibilities is crucial to provide evidence of a robust access control system and segregation of duties.
 - iii. It is necessary to define a security and standards baseline of secure storage mechanisms for encryption keys, such as hardware security modules (HSMs), key vaults, or other trusted environments.
 - iv. The organization must maintain documentation and audit trails of key suspension and disposal activities.
- c. **Document procedures for:**
 - i. secure distribution of encryption keys.
 - ii. periodic validation of secure communication channels (e.g., encrypted connections) for transmitting encryption keys.
 - iii. limiting the usage of encryption to authorized individuals and purposes. This process must adhere to the organization's key management policies, and
 - iv. securely suspending and disposing of encryption keys.

4. **Deployment and Management**

The organization should undertake the following actions:

- a. Maintain an up-to-date inventory of issued and active keys, including owners, users, purpose and usage, types, and expiration dates whenever applicable.
- b. Establish and document a procedure to rotate, renew, and revoke encryption keys.
- c. Perform regular assessments of the logical, physical security controls protecting the key storage infrastructure when available.
- d. Define and follow strong access controls, including authentication and authorization. The emphasis is to restrict key access to authorized personnel only.
- e. Set up monitoring and alert systems to detect unauthorized attempts to access or tamper with encryption keys.
- f. Periodically review and validate the identity of recipients before transmitting encryption keys.
- g. Keep a record of usage of any encryption key, detailing actors, functions, location, and time.
- h. Demonstrate a detection mechanism's existence and periodic validation to alert and

- prevent unauthorized or abnormal key usage patterns.
- i. Have an up-to-date inventory of encryption keys, regardless of their status (e.g., active or suspended).
- j. Have a process to review encryption key-related logs and audit trails regularly. Reviews should focus on monitoring and identifying suspicious (and anomalous) activities regarding cryptographic materials. These reviews should correlate key usage with current organizations' security policies and regulations.
- k. Conduct regular reviews to validate that retired keys have been effectively removed from active use and disposed of securely. Suspended keys shall only be used only for decryption, never for encryption. And disposed keys should not be recoverable.
- l. Have procedures for periodic backups of encryption keys. Key backups should have the same security and stringency as the keys itself.
- m. Perform periodic reviews (with evidence) of encryption key backup and recovery processes to validate functionality adherence to organizational requirements.

6. Industry Specific Differences

Cryptographic operations are pivotal across various industries in today's diverse digital landscape. Each sector operates within a distinct regulatory framework and adheres to specific standards to address its unique challenges and risks. Consequently, organizations operating within these industries must comply with these stringent regulatory and compliance requirements.

For instance, companies handling their customers' credit card data must adhere to the rigorous mandates of the Payment Card Industry - Data Security Standard (PCI-DSS). PCI-DSS outlines how organizations should securely store, process, and transmit credit card information. It encompasses critical aspects such as key generation, robust cryptographic algorithms and key lengths, regular key rotation, and strict access controls, including separating key-encrypting and data-encrypting keys.

Organizations involved in credit card production face an even more demanding set of standards known as the Payment Card Industry - Card Production and Provisioning (PCI-CPP). PCI-CPP delves into the use of specialized security hardware like hardware security modules (HSMs) and delineates precise operational procedures for initiating, managing, auditing, and decommissioning HSMs. Furthermore, it intricately defines various roles in cryptographic key management, emphasizing the necessity of distributing these roles across the organization. For example, multiple parties must collaborate to generate or construct an encryption key, ensuring that no single team or department possesses complete key composition authority. Similarly, the personnel handling encryption and key management responsibilities should have a separation of duties from the personnel handling cryptographic key operational tasks.

Another example of industry-specific requirements is the Health Insurance Portability and Accountability Act (HIPAA), which governs the handling and encryption of personal health-related electronic data. HIPAA's multifaceted requirements extend to encryption key generation, secure storage, periodic rotation, and usage protocols.

Secure key management is paramount in the financial services industry, especially concerning digital currencies and blockchain technology. Organizations must rigorously follow best practices for key generation, storage, rotation, and recovery. Hardware security modules (HSMs) are highly recommended to safeguard private keys against unauthorized access. Furthermore, the ecosystem often mandates using Multi-Signature Wallets, employing multi-signature mechanisms that require multiple parties to authorize transactions. This layered approach enhances security by preventing individuals from completely controlling private keys. Additionally, token standards, such as Ethereum's ERC-20 tokens, necessitate adherence to specific behavior and functionality protocols, especially for security tokens requiring cryptographic operations for ownership verification and access control.

In the defense and military sectors, where protecting sensitive information is paramount, secure communication, data protection, and authentication are critical. Tamper-resistant hardware is essential, as cryptographic modules and devices used in military contexts must withstand physical attacks and resist the extraction of sensitive data. Hardware security modules (HSMs) and trusted execution environments are commonly employed. The Federal Information Processing Standard (FIPS) 140-2 provides stringent security requirements for cryptographic modules, including HSMs, and is widely adopted in government and military environments to ensure the security of cryptographic operations. Furthermore, military-specific standards like MIL-STD-1553, which defines digital communication buses for integrating avionics systems, and STANAG 5516, the NATO standard for secure communication protocols and cryptographic techniques, are rigorously applied. These standards also guide secure satellite communication to safeguard sensitive information transmitted via military satellites, including reconnaissance data and troop movements that require cryptographic techniques. These guidelines and specifications are instrumental in preventing unauthorized interception or tampering of critical communications.

Cryptographic operations serve as critical functions for data security across various industries, each with its unique set of regulations and standards. Most of the time, adherence to these standards is non-negotiable, as it ensures the confidentiality, integrity, and availability of sensitive information in an increasingly interconnected digital world.

7. On Premises-Considerations

Organizations considering an on-premises key management system (KMS) deployment should carefully evaluate their security needs and compliance requirements. The choice between on-premises and cloud-hosted KMS has benefits and challenges, ultimately depending on the specific organizational context. Organizations should consider these characteristics before they opt for an on-premises KMS:

Physical Control:

- On-premises KMS is physically located within the organization's data center, allowing direct physical access for administrators.
- It provides the opportunity to maintain compliance with corporate physical and information security standards.

Data Sovereignty and Residency Requirements:

- Some countries have stringent data residency and sovereignty requirements. On-premises KMS enables organizations to meet these requirements by keeping encryption keys, encryption engines, and data processing on-site.

Latency and Performance:

- On-premises deployments may offer lower latency and superior performance for on-premises applications.
- It is particularly advantageous when low latency and high performance are critical, provided no configuration or other issues exist.

Redundancy and Availability:

- In on-premises deployments, organizations are responsible for ensuring redundancy and availability, like any other data center service.
- Cloud-native or hosted KMS solutions relieve organizations of these concerns.

Scalability:

- Cloud KMS often provides on-demand scalability through the service provider.
- On-premises deployments require careful hardware and software redundancy planning to accommodate growing usage demands.

Maintenance and Patching:

- Hardware and software hosting the on-premises KMS need periodic maintenance and vulnerability patching following organizational change management processes.

Support Staff:

- On-premises KMS requires adequate support staff to manage the KMS hardware, software, and associated infrastructure within corporate data centers.

Cost:

- Considering factors like maintenance, support, and hardware, on-premises KMS can sometimes be more expensive than cloud-hosted alternatives.

Security Controls:

- On-premises KMS allows organizations to implement tailored security controls to meet compliance and internal security policies.

Integration with Existing Infrastructure:

- On-premises KMS seamlessly integrates with on-premises infrastructure, including authentication systems, databases, and applications.

Customization and Flexibility:

- On-premises KMS can be customized to specific requirements, workflows, and processes, offering greater control and flexibility.

Auditability and Compliance:

- On-premises KMS facilitates auditing and compliance with regulatory requirements, providing direct control over the system.

Risk Mitigation:

- On-premises KMS mitigates risks associated with third-party service providers, making it suitable for organizations with higher risk tolerance or concerns.

Data Privacy:

- On-premises KMS enhances data privacy by keeping encryption keys under physical control, reducing exposure to external parties.

Organizational Policies:

- Some organizations may have policies or regulations that mandate using on-prem KMS for specific data or applications.

Hybrid Deployments:

- Organizations can combine on-premises KMS with cloud-based solutions in a hybrid model, offering flexibility and scalability while maintaining control over critical encryption keys.

In conclusion, the choice between on-premises and cloud-hosted KMS depends on numerous factors. Technology or capability owners should thoroughly consider these points before making a decision. Each organization's unique security policy, risk appetite, compliance requirements, and operational needs will dictate the most suitable deployment model for their KMS.

8. Conclusion

Effective management of cryptographic keys is paramount to maintaining the confidentiality and integrity of sensitive data and systems. This paper describes the key management service life cycle and associated best practices, focusing on the planning and secure deployment of key management solutions.

The key management life cycle comprises several critical phases: key generation, storage, distribution, rotation, revocation, and destruction. Organizations can establish a robust and secure key management framework by following the best practices outlined in this paper. Proper key distribution mechanisms ensure the transfer of keys to authorized entities securely. It may involve secure channels, key wrapping techniques, or protocols to protect keys during transmission. Regular key rotation and revocation are essential practices to mitigate the risks associated with compromised keys. Organizations can enhance their data security posture by periodically updating keys and promptly revoking any compromised or unauthorized keys. Additionally, Organizations should implement proper key destruction procedures when keys are no longer needed or have reached their designated expiration dates to help prevent potential key misuse and unauthorized access.

Organizations should carefully assess their requirements during the planning phase, including compliance obligations and industry standards. Doing so enables them to select appropriate key management solutions that align with their needs and ensure regulatory compliance. Organizations should implement secure key storage mechanisms in the deployment phase, such as cloud hardware security modules (HSMs) or cloud-based key management services (KMS). These solutions provide robust security and logical protections for encryption keys, ensuring their confidentiality and integrity.

Organizations should enforce strong access controls throughout the key management life cycle, implement comprehensive auditing and logging mechanisms, and ensure compliance with relevant regulatory requirements and industry standards.

By adopting these best practices, organizations can establish a solid foundation for effective cryptographic key management, protecting their sensitive data, and mitigating the risks of unauthorized access and data breaches. It is important to note that key management is an ongoing process that requires continuous monitoring, assessment, and adaptation to evolving threats and technologies. Organizations should conduct regular reviews and audits to evaluate key management practices' effectiveness and to identify areas for improvement.

9. References

- [1] NIST. (2020). NIST SP 800-175B rev.1. Guideline for Using Cryptographic Standards in the Federal Government: Cryptographic Mechanisms.
<https://csrc.nist.gov/pubs/sp/800/175/b/r1/final>
- [2] Recommendation ITU-T X.509 (2019) – Technical Corrigendum 1.
<https://www.itu.int/rec/T-REC-X.509>
- [3] CSA. (2020). Key Management in Cloud Services. The Cloud Key Management working group.
<https://cloudsecurityalliance.org/artifacts/key-management-when-using-cloud-services/>
- [4] NIST. (2020). NIST SP 800-57 Part 1 Rev.5. Recommendations for Key Management: Part 1-General.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>
- [5] ISO. (2000). ISO/IEC 7498-1:1994. Information technology — Open Systems Interconnection — Basic Reference Model: The Basic Model.
<https://www.iso.org/standard/20269.html>
- [6] CSA. (2021). Recommendations for Adopting a Cloud-Native Key Management Service. The Cloud Key Management working group.
<https://cloudsecurityalliance.org/artifacts/recommendations-for-adopting-a-cloud-native-key-management-service/>
- [7] NIST. COMPUTER SECURITY RESOURCE CENTER. Key Management Policy.
https://csrc.nist.gov/glossary/term/key_management_policy
- [8] NIST. (2015). NIST SP 800-57 Part 3 Rev. 1. Recommendation for Key Management, Part 3: Application-Specific Key Management Guidance.
<https://csrc.nist.gov/pubs/sp/800/57/pt3/r1/final>
- [9] Microsoft. (2023). Azure Key Vault soft-delete overview.
<https://learn.microsoft.com/en-us/azure/key-vault/general/soft-delete-overview>
- [10] Microsoft Learn. (2023). Regulatory Compliance details for NIST SP 800-53 Rev. 5. Details of the NIST SP 800-53 Rev. 5 Regulatory Compliance built-in initiative.
<https://learn.microsoft.com/en-us/azure/governance/policy/samples/nist-sp-800-53-r5>
- [11] AWS. Multi-Region keys in AWS KMS.
<https://docs.aws.amazon.com/kms/latest/developerguide/multi-region-keys-overview.html>
- [12] Microsoft. (2023). Azure Key Vault availability and redundancy.
<https://learn.microsoft.com/en-us/azure/key-vault/general/disaster-recovery-guidance>

and Google Cloud. (2023). Cloud Key Management Service deep dive.
<https://cloud.google.com/docs/security/key-management-deep-dive>

[13] AWS. Rotating AWS KMS keys.
<https://docs.aws.amazon.com/kms/latest/developerguide/rotate-keys.html>

[14] AWS. Update management in AWS CloudHSM.
<https://docs.aws.amazon.com/cloudhsm/latest/userguide/update-management.html>

and Google Cloud. (2023). Cloud HSM architecture.
<https://cloud.google.com/docs/security/cloud-hsm-architecture>

[15] Google Cloud. (2023). Cloud HSM architecture.
<https://cloud.google.com/docs/security/cloud-hsm-architecture>

Other sources:

Rivest, Ronald L. (1990). "Cryptography." In J. Van Leeuwen (ed.). Handbook of Theoretical Computer Science. Vol. 1. Elsevier.
<https://people.csail.mit.edu/rivest/pubs/Riv90a.pdf>

AWS (n.d.). AWS KMS concepts - AWS Key Management Service. AWS.
<https://docs.aws.amazon.com/kms/latest/developerguide/concepts.html#enveloping>

CSA. (2021). Recommendations for Adopting a Cloud-Native Key Management Service.
<https://cloudsecurityalliance.org/artifacts/recommendations-for-adopting-a-cloud-native-key-management-service/>

Appendix A: Acronyms

Acronym	Full Term
AES	Advanced Encryption Standard
API	Application Programming Interface
BYOK	Bring Your Own Key
BSI AIS	Bundesamt für Sicherheit in der Informationstechnik (BSI)
CC	Common Criteria
CIA (triad)	Confidentiality, Integrity, and Availability
CSP	Cloud Service Provider
ECC	Elliptic Curve Cryptography
GDPR	General Data Protection Regulation
GP	General Purposes
FIPS	Federal Information Processing Standard
HIPAA	Health Insurance Portability & Accountability Act
HSM	Hardware Security Module
HYOK	Hold Your Own Key
ISO	The International Organization for Standardization
KMS	Key Management System
NIST	National Institute of Standards & Technology
PaaS	Platform as a Service
PCI DSS	Payments Card Industry Data Security Standard
RNG	Random Number Generator
SDK	Software Development Kit
3DES	Triple Data Encryption Algorithm
USB (cable)	Universal Serial Bus (cable)